Machine Translated by Google

Máy tính & Bảo mật 155 (2025) 104454

Danh sách nội dung có sẵn tại ScienceDirect

Máy tính & Bảo mật

trang chủ tạp chí: www.elsevier.com/locate/cose

Bài viết đầy đủ

Kiểm tra thâm nhập tự động: Chính thức hóa và hiện thực hóa

Charilaos Skandylas ,Mikael Asplund

Khoa Khoa học Thông tin và Máy tính, Đại học Linköping, Linköping, Thụy Điển

THÔNG TIN BÀI VIẾT

Liên kết tập dữ liệu: https://gitfront.io/r/anonymous-s ummitter/P2LRhxvh9L7z/ADAPT/

Từ khóa:
Kiểm tra thâm nhập tự động
Kế hoạch tấn công
Tự động hóa tấn công
Mô hình chính thức

TÓM TẮT

Những thay đổi gần đây về tiêu chuẩn và quy định, do tầm quan trọng ngày càng tăng của hệ thống phần mềm trong việc đáp ứng nhu cầu xã hội, đã yêu cầu tăng cường kiểm tra bảo mật cho các hệ thống phần mềm. Kiểm tra thâm nhập đã được chứng minh là một phương pháp đáng tin cậy để đánh giá bảo mật hệ thống phần mềm. Tuy nhiên, kiểm tra thâm nhập thủ công đòi hỏi nhiều nhân lực và kỹ năng chuyên môn cao. Do thiếu hụt chuyên gia an ninh mạng và nhu cầu xã hội hiện nay, việc tăng cường mức độ tự động hóa trong kiểm tra thâm nhập có thể hỗ trợ đáp ứng nhu cầu kiểm tra bảo mật ngày càng tăng. Trong nghiên cứu này, chúng tôi chính thức trình bày vấn đề kiểm tra thâm nhập ở cấp độ kiến trúc và đề xuất một kiến trúc tự tổ chức chung có thể được khởi tạo để tự động kiểm tra thâm nhập trên các hệ thống thực. Chúng tôi tiếp tục mô tả và triển khai một kiến trúc chuyên biệt trong ADAPT, một công cụ kiểm tra thâm nhập tự động dựa trên kiến trúc , nhắm mục tiêu vào các hệ thống bao gồm máy chủ và dịch vụ. Chúng tôi đánh giá và chứng minh tính khả thi của ADAPT bằng cách tự động thực hiện các bài kiểm tra thâm nhập thành công trên: Metasploitable2, Metasploitable3 và một mạng ảo thực tế được sử dụng làm môi trường phòng thí nghiệm để đào tạo kiểm tra thâm nhập.

1. Giới thiệu

Hệ thống máy tính hiện diện khắp nơi trong xã hội và an ninh mạng đang trở thành mối quan tâm hàng đầu không chỉ đối với doanh nghiệp và cá nhân mà còn đối với an ninh quốc gia. Cơ sở hạ tầng quan trọng, dịch vụ chăm sóc sức khỏe và dịch vụ chính phủ là những ví dụ về các lĩnh vực mà an ninh mạng đang trở thành ưu tiên hàng đầu. Trong vài năm gần đây, mối lo ngại về an ninh đã dẫn đến việc gia tăng các quy định và yêu cầu của ngành về các biện pháp kỹ thuật bảo mật nghiêm ngặt được áp dụng cho các hệ thống này. Nhiều quy định và tiêu chuẩn (ví dụ: HIPA, PCI DCSS2 và SWIFT CSF3) hiện nay yêu cầu áp dụng kiểm tra bảo mật, tức là kiểm tra thâm nhập.

Một mặt, kiểm thử thâm nhập chỉ là một hình thức kiểm thử khác, vốn là một kỹ thuật cơ bản trong mọi lĩnh vực kỹ thuật và nó kế thừa phần lớn các nguyên tắc từ kiểm thử phần mềm nói riêng. Mặt khác, kiểm thử thâm nhập đặc biệt ở chỗ nó trùng lặp đáng kể với các hoạt động và phương pháp được thực hiện bởi tội phạm và các cơ quan quốc gia thù địch. Kết quả là, một hệ sinh thái hoàn chỉnh các công cụ và phương pháp đòi hỏi một dạng chuyên môn rất cụ thể để triển khai và vận hành đúng cách đã xuất hiện. Mặc dù ngày càng có nhiều nỗ lực đào tạo sinh viên về tin tặc đạo đức, nhưng vẫn còn thiếu rất nhiều nguồn nhân lực có thể thực hiện kiểm thử thâm nhập hiệu quả ở cấp độ này.

rằng chúng ta cần đảm bảo rằng các hệ thống trong tương lai sẽ an toàn hơn và có khả năng chống lại các cuộc tấn công ngày càng tinh vi và thường xuyên hơn.

Một giải pháp tiềm năng cho vấn đề này là cung cấp các công cụ tốt hơn để tự động hóa phần lớn quy trình kiểm tra xâm nhập, do đó giảm bớt nỗ lực và đào tạo của con người cần thiết để bắt đầu triển khai kiểm tra xâm nhập trên các hệ thống. Có một số đề xuất trong tài liệu về kiểm tra xâm nhập tự động. Một hướng đã được theo đuổi là sử dụng biểu đồ tấn công để tạo ra các kế hoạch cho kẻ tấn công (Obes và cộng sự, 2013). Điều này có khả năng cho phép tìm ra con đường tốt nhất thông qua một hệ thống, tuy nhiên, vẫn còn thiếu các công trình chứng minh cách các kế hoạch như vậy có thể được chuyển giao vào các tình huống kiểm tra xâm nhập thực tế. Một cách tiếp cận khác đã được khám phá bởi một số công trình (Jagamogan và cộng sự, 2022; Clintswood và cộng sự, 2023) là sử dụng máy học để đào tạo một mô hình thực hiện các cuộc tấn công dựa trên dữ liệu có sẵn. Nhược điểm của cách tiếp cận này là thiếu dữ liệu có sẵn để đào tạo và cần phải đào tạo lại khi có đủ thay đổi trong hệ thống.

Cuối cùng, các phương pháp học tăng cường (RL) (Zhou và cộng sự, 2019; Hu và cộng sự, 2020; Zhou và cộng sự, 2021) cho phép các tác nhân hoạt động mà không cần giai đoạn huấn luyện ban đầu, tuy nhiên, việc khởi tạo trên các hệ thống thực tế vẫn chưa được chứng minh rộng rãi. Hơn nữa, ý nghĩa của thuật ngữ kiểm thử thâm nhập tự động cũng được diễn giải khác nhau trong các bài báo khác nhau, với trọng tâm chính của hầu hết các công trình là tấn công.

Tác giả liên hệ.
Địa chỉ email: charilaos.skandylas@liu.se (C. Skandylas), mikael.asplund@liu.se (M. Asplund).

1 csrc.nist.gov/pubs/sp/800/66/r2/final.
2 east.pcisecuritystandards.org/document_library?category=pcidss&document=pci_dss.
3 www2.swift.com/knowledgecentre/publications/cscf_dd/53.0.

https://doi.org/10.1016/j.cose.2025.104454 Nhận ngày 17 tháng 12 năm 2024; Nhận bản sửa đổi ngày 26 tháng 2 năm 2025; Chấp nhận ngày 19 tháng 3 năm 2025. Có sẵn trực tuyến ngày 28 tháng 3 năm 2025 0167-4048/© 2025 The Authors.
Xuất bản bởi Elsevier Ltd. Đây là bài viết truy cập mở theo giấy phép CC BY (http://creativecommons.org/licenses/by/4.0/).

Machine Translated by Google

lập kế hoạch, đây chỉ là một phần của quá trình kiểm tra thâm nhập. Điều này gợi ý về nhu cầu cần có định nghĩa chính xác về những yếu tố nào là cần thiết để tự động hóa quá trình kiểm tra thâm nhập khi nhắm mục tiêu thực tế hệ thống.

Hầu hết các công trình hiện có đã đánh giá hiệu quả của chúng trong mạng lưới môi trường mô phỏng, thay vì các mạng thực tế có thể biểu hiện các hành vi khác nhau khi nói đến hiệu quả và hậu quả của sự bóc lột. Thật vậy, trong một so sánh gần đây về quyền tự chủ các tác nhân kiểm tra thâm nhập, Simon và Mees (2024), xác định rõ ràng thách thức nghiên cứu để thành công trong thử nghiệm thâm nhập thế giới thực môi trường.

Trong bài báo này, chúng tôi chính thức trình bày vấn đề kiểm tra thâm nhập tại mức độ kiến trúc với các yếu tố cấu thành là các thành phần và giao diện. Biểu diễn cấp cao này có thể được khởi tạo trên một số lượng các hệ thống thực tế khác nhau như mạng lưới máy chủ hoặc một máy chủ duy nhất có nhiều quy trình, dựa trên thành phần hoặc hướng dịch vụ hệ thống, v.v. Bằng cách xây dựng chính xác vấn đề kiểm tra thâm nhập tự động, chúng tôi giúp bạn dễ dàng lý giải hơn về các hiệu suất khác nhau số liệu, cũng như để cộng đồng mở rộng và tinh chỉnh công thức để cho phép các mục tiêu và/hoặc ràng buộc thay thế. Của chúng tôi công thức đề xuất mang tính tổng quát hơn so với các công thức dựa trên lập kế hoạch RL hoặc AI tương ứng vì có thể dễ dàng xây dựng một ánh xạ từ hầu hết các công thức lập kế hoạch dựa trên RL hoặc AI sang chủ nghĩa hình thức.

Hơn nữa, chúng tôi trình bày một kiến trúc để giải quyết vấn đề tự động hóa vấn đề kiểm tra thâm nhập dựa trên nguyên lý tính toán tự động (tức là sử dụng vòng lặp MAPE-K (Kephart và Chess, 2003)). Kiến trúc có khả năng xử lý động lực hệ thống và đưa ra quyết định tại thời gian chạy để cung cấp hiệu quả, ví dụ, không lặp lại các cuộc tấn công với mục tiêu giống nhau/tương tự. Nó cũng có thể đưa ra quyết định tại thời điểm chạy để cung cấp hiệu quả bằng cách lựa chọn các công cụ khai thác một cách năng động và triển khai các công cụ khai thác sau trên phần được khai thác của hệ thống để khám phá càng nhiều hệ thống càng tốt và khai thác sâu nhất có thể.

Cuối cùng, chúng tôi cung cấp ADAPT, một triển khai cụ thể của kiến trúc này sử dụng các công cụ kiểm tra thâm nhập hiện đại như metasploit, sqlmap, v.v. Theo hiểu biết của chúng tôi, hiện không có các phương pháp kiểm tra thâm nhập tự động trước đây có thể thực hiện toàn bộ quá trình kiểm tra thâm nhập. Điểm mới lạ trong cách tiếp cận của chúng tôi là đã bắt nguồn từ khả năng thực hiện kế hoạch tấn công trực tuyến và quyết định thời gian chạy thực hiện để xử lý những thay đổi trong trạng thái hệ thống và những phát hiện mới thông tin ngoài việc cung cấp khả năng tự động hóa tấn công cần thiết khả năng nhắm mục tiêu vào các hệ thống trong thế giới thực.

ADAPT là một công cụ kiểm tra xâm nhập hộp đen cũng cung cấp Khả năng hộp trắng và hộp xám. Chúng tôi đánh giá việc triển khai cụ thể và chứng minh rằng phương pháp của chúng tôi là thiết thực trong một bối cảnh thực tế. thiết lập. Với một bộ công cụ kiểm tra thâm nhập đầy đủ, hoạt động của chúng được tự động hóa, ADAPT thực hiện thành công việc kiểm tra thâm nhập thử nghiệm, không có sự tương tác của con người, chống lại Metasploitable2 và Máy ảo Metasploitable3 cũng như mạng ảo thực tế.

Tóm lại, những đóng góp của bài báo này là:

- Xây dựng thử nghiệm thâm nhập trong bối cảnh kiến trúc, cung cấp mô tả vấn đề chính thức đủ sức diễn đạt để kết hợp các công thức trước đó vào một khuôn khổ thống nhất.
- Đề xuất một kiến trúc kiểm tra xâm nhập tự động chung, sử dụng một người quản lý tự chủ để lý luận về vấn đề chung, các quyết định cấp cao và cung cấp khả năng tự động hóa tấn công.
- Triển khai và đánh giá kiến trúc so với thực tế thiết lập mạng.

Phần còn lại của bài báo này được cấu trúc như sau. Trong Phần 2, chúng tôi trình bày công việc liên quan. Phần 3 cung cấp phần giới thiệu cấp cao đến mô hình kiến trúc bảo mật và hệ thống tự thích ứng. Phần 4 giới thiệu và xây dựng vấn đề kiểm tra thâm nhập. Phần 5 thảo luận về kiến trúc chung của chúng tôi và quá trình khởi tạo của chúng tôi cho hệ thống bao gồm máy chủ và dịch vụ. Phần 6 trình bày chi tiết về việc đánh giá của hai nghiên cứu điển hình. Phần kết luận của bài báo được trình bày ở Phần 7.

2. Công việc liên quan

Bất kỳ giải pháp kiểm tra xâm nhập tự động nào cũng yêu cầu hai tính năng chính: tự động hóa tấn công và lập kế hoạch tấn công (Wang và cộng sự, 2025). Do đó, trong phần này chúng tôi xem xét lại các cách tiếp cận trước đây liên quan đến với hai tính năng này. Chúng tôi kết thúc phần này bằng một so sánh các cách tiếp cận khác nhau liên quan đến khả năng tự động hóa của họ kiểm tra khả năng xâm nhập của mạng thực tế.

Tự động hóa tấn công có thể được cung cấp một phần ở các mức độ khác nhau bằng các công cụ có sẵn bao gồm metasploit (Holik et al., 2014), cobalt-strike4 và canvas5 tuy nhiên, các công cụ này không cung cấp bất kỳ lý luận nào hoặc khả năng ra quyết định tự động cần thiết để đánh giá trạng thái bảo mật và quyết định mục tiêu hoặc cuộc tấn công tiếp theo là gì. Hơn nữa, tự động hóa tấn công đã được chứng minh trong DARPA Grand Cyber Thách thức (Lee, 2015). Cả các công cụ có sẵn và khả năng được chứng minh bởi DARPA Grand Cyber Challenge trực tiếp tại lần thứ 2 mức độ tự chủ liên quan đến nghiên cứu khả thi sơ bộ của NATO IAG về các hoạt động tự động (Williams, 2015). Tự động, tại thời điểm chạy việc ra quyết định và lý luận là điều cần thiết để vượt qua cấp độ 2 để mức độ tự chủ cao hơn. Tự động hóa tấn công là một phần quan trọng của Tuy nhiên, bản thân việc kiểm tra thâm nhập không thể cung cấp mức độ cần có sự tự chủ để tự động hóa toàn bộ quá trình kiểm tra thâm nhập. công việc hướng tới mức độ tự chủ cấp độ 3 hoặc cao hơn.

Lập kế hoạch tấn công Phần công việc chính liên quan đến tự động hóa xâm nhập, khi nói đến việc lập kế hoạch tấn công, thử nghiệm xoay quanh tự động hóa việc lựa chọn và lập kế hoạch tấn công. Có hai hướng chính đã được thực hiện: (i) lập kế hoạch AI (cổ điển) và (ii) lập kế hoạch AI chuyên sâu học tập và/hoặc học tăng cường (Wang và cộng sự, 2025).

Obes et al. (2013) sử dụng biểu đồ tấn công để tạo ra một kế hoạch ngôn ngữ định nghĩa miền (PDDL) biểu diễn mô hình tấn công và tạo ra một kế hoạch tấn công cho các công cụ kiểm tra xâm nhập. Sarraute và cộng sự. (2013) mã hóa vấn đề kiểm tra thâm nhập dưới dạng một quy trình quyết định Markov có thể quan sát được một phần (POMDP). Các tác giả sử dụng kinh nghiệm đánh giá trên một cặp máy để xác thực giải pháp và nắm bắt sự không chắc chắn trong kết quả của hành động tấn công bằng cách sử dụng các khuôn khổ PDDL bao gồm các hiệu ứng xác suất. Sarraute và cộng sự (2011) cũng cung cấp một phương pháp tiếp cận nhận biết xác suất theo từng kịch bản cụ thể để lập kế hoạch tấn công có thể mở rộng. Durkota và Lisy (2014) cũng mã hóa kế hoạch tấn công như một vấn đề được thể hiện qua quá trình quyết định Markov (MDP) và tìm ra giải pháp tối ưu đường dẫn/chiến lược sử dụng thuật toán phân nhánh và cận. Các phương pháp lập kế hoạch AI có lợi thế là cung cấp các đảm bảo tối ưu, Tuy nhiên, các phương pháp giải quyết chính xác có độ phức tạp tính toán lớn, hạn chế khả năng mở rộng của chúng. Hơn nữa, các phương pháp lập kế hoạch AI thường yêu cầu kiến thức về hệ thống đang được kiểm tra thâm nhập và do đó, khó sử dụng khi thâm nhập hộp xám và hộp đen cần phải thử nghiệm.

Chowdhary và cộng sự (2020) đề xuất khuôn khổ ASAP xác định mối quan hệ phụ thuộc giữa các lỗ hổng và khả năng kết nối mạng để cung cấp mô hình phần thưởng cụ thể cho từng miền. Xác suất chuyển đổi được liên kết với cấu trúc mạng và độ phức tạp của truy cập. và các giá trị phần thưởng có liên quan đến điểm CVSS về mức độ dễ bị tổn thương- khả năng. Họ sử dụng một khuôn khổ Học tăng cường (RL) dựa trên trên Deep Q-Networks để tìm hiểu các kế hoạch kiểm tra thâm nhập hiệu quả trên quy mô lớn mạng lưới. Zhou và cộng sự (2019) giới thiệu một sơ đồ phân tích hành động hiệu quả và linh hoạt trong việc phát triển chiến lược tấn công trong các cấu hình mạng khác nhau. Phương pháp đề xuất sử dụng RL đa tác nhân để phân chia không gian hành động thành các tập nhỏ hơn và đào tạo các tác nhân RL riêng lẻ trong mỗi tập hợp hành động.

Hu et al. (2020) trình bày một khuôn khổ thử nghiệm thâm nhập tự động để tìm ra đường tấn công tốt nhất cho một cấu trúc mạng nhất định, hoạt động tương tự như một kẻ tấn công con người. Họ xây dựng một biểu diễn tấn công

[4] https://www.cobaltstrike.com/product.

[5] https://www.immunityinc.com/products/canvas/.

Machine Translated by Google

Bảng 1
So sánh các công trình liên quan.

Tài liệu tham khảo	Loại kiểm tra thâm nhập			Đặc trưng			Sự đánh giá môi trường	Miền giải pháp	Mức độ tự chủ
	Hộp trắng	Hộp xám	Hộp đen	Tấn công tự động hóa	Tấn công lập kế hoạch	Quyết định thời gian chạy			
Obes và cộng sự (2013), Sarraute và cộng sự. (2011, 2013) và Durkota và Lisy (2014)	✓	✗	✗	★	✓	✗	Mô phỏng	---- Lập kế hoạch	3
Ghanem và Chen (2020), Tran và cộng sự (2021) và Wang và cộng sự (2023)	✓	✗	✗	★	✓	✗	Mô phỏng	Học tăng cường	3
Ghanem và cộng sự. (2023) và Hoàng và cộng sự. (2022)	✓	✗	✗	★	✓	✗	Mạng VM	Tăng cường học hỏi	3
Li và cộng sự (2025)	✓	✓	✗	★	✓	✗	Mạng VM	Học tăng cường	3
Chowdhary và cộng sự (2020)	✓	✗	✗	★	✓	✗	Mô phỏng	Học tăng cường	3
Zhou và cộng sự (2019)	✗	✗	✓	★	✓	✗	Mạng VM	Học tăng cường	3
Hu và cộng sự (2020)	✓	✗	✗	☆	✓	✗	Mô phỏng	Học tăng cường	–
Chen và cộng sự (2023)	✓	✗	✗	★	✓	✗	Mô phỏng	Tăng cường học hỏi	–
Chu và cộng sự. (2021) và Li và cộng sự. (2023)	✗	✓	✗	☆	✓	✗	Mô phỏng	Học tăng cường	–
Công việc này	✓	✓	✓	★	✓	✓	Mạng VM	Tính toán tự động	3

★ Khả năng tự động hóa có thể mở rộng/mô-đun, Wrapper trên Metasploit, ★ ☆ Mô-đun kiểm tra xâm nhập chưa được triển khai.

ma trận bằng cách sử dụng thuật toán MulVAL và Tìm kiếm theo Độ sâu (DFS). Phương pháp mạng Học sâu (Deepth-First-Learning) được sử dụng để phân tích ma trận tấn công và tìm đường tấn công tối ưu. Trong nghiên cứu của Zhou và cộng sự (2021), các tác giả mô hình hóa thử nghiệm thâm nhập như một bài toán quy trình quyết định Markov (MDP). Họ trình bày một mạng q sâu để đào tạo tác nhân kiểm tra xâm nhập có thể học chính sách tấn công tối ưu mà không cần kiến thức trước.

Faillon và cộng sự (2024) cung cấp một phương pháp tiếp cận dựa trên chính sách để cải thiện khả năng khái quát hóa của tác nhân tấn công học tăng cường phân cấp đối với các kịch bản chưa biết trước đó. Li và cộng sự (2023) đề xuất một phương pháp học sâu phân cấp, sử dụng kiến thức chuyên môn trước đó để hướng dẫn khám phá và thu hẹp không gian trạng thái và hành động. Chen và cộng sự (2023) khai thác học bắt chước đối kháng sinh sinh kết hợp với kiến thức chuyên môn để cải thiện sự hội tụ khi quyết định các hành động tiếp theo mà tác nhân kiểm tra thâm nhập sẽ thực hiện trong không gian hành động lớn.

Ghanem và Chen (2020) mô hình hóa việc lập kế hoạch tấn công như một bài toán giải POMDP, và so sánh các bộ giải dựa trên lập kế hoạch chính xác và các bộ giải gần đúng dựa trên học tăng cường về khả năng tổng hợp các kế hoạch hợp lý. Trong phần mở rộng của công trình trước đây của họ (Ghanem và cộng sự, 2023), họ sử dụng học tăng cường phân cấp, phân tích vấn đề RL thành một số vấn đề con để giải quyết vấn đề về khả năng mở rộng của học tăng cường trong không gian hành động lớn. Hoang et al. (2022) sử dụng thuật toán A3C và học tăng cường sâu để xác định các khai thác tối ưu bằng cách sử dụng thông tin thu được trong quá trình trinh sát trước đó. Tran et al. (2021) đề xuất một kiến trúc học tăng cường tác nhân phân cấp mới sử dụng phân tích tác nhân học tăng cường để giải quyết các tình huống không gian hành động rời rạc lớn. Wang et al. (2023) tích hợp học tăng cường và học bắt chước với kiến thức chuyên môn để lập kế hoạch tấn công bằng cách sử dụng thuật toán Học Q sâu từ các cuộc trình diễn (DQfD). Li et al. (2025), tích hợp Phát lại trải nghiệm nhìn lại (HER) với phương pháp DRL cho phép các tác nhân học các mẫu kinh nghiệm tấn công, bao gồm cả những nỗ lực không thành công với mục đích cải thiện sự hội tụ của mô hình.

Tính khả thi của các phương pháp trên đã được chứng minh bằng cách sử dụng các trình mô phỏng mạng, phổ biến nhất là NASim và CybORG (Standen và cộng sự, 2021). Đây là phương pháp duy nhất, ngoài phương pháp của chúng tôi, nhằm mục tiêu vào các hệ thống thực tế và thực hiện xâm nhập hộp đen.

Machine Translated by Google

Thử nghiệm, mặc dù có khả năng tự động hóa tấn công hạn chế, là Zhou và cộng sự (2019). Đáng tiếc là các tác giả không cung cấp mã hoặc gói sao chép môi trường cho các thí nghiệm, khiến việc so sánh với phương pháp đó về mặt định lượng trở nên khó khăn.

Ngược lại với các phương pháp hướng đến tự động hóa việc lập kế hoạch tấn công, phương pháp của chúng tôi cung cấp một kiến trúc đầu cuối chung để tự động hóa toàn bộ quy trình kiểm tra xâm nhập. Triển khai tham chiếu của chúng tôi, ADAPT, cung cấp cả khả năng lập kế hoạch tấn công và tự động hóa tấn công, do đó có thể được sử dụng để nhắm mục tiêu vào các hệ thống thực như nghiên cứu điển hình về máy ảo (VM) của chúng tôi đã chỉ ra. Hầu hết các phương pháp dựa trên lập kế hoạch, học sâu hoặc học tăng cường, đều yêu cầu lượng thông tin khác nhau về hệ thống mục tiêu để huấn luyện các mô hình học tập của chúng hoặc để tạo ra chiến lược lập kế hoạch. Phương pháp của chúng tôi không yêu cầu kiến thức về kiến trúc hệ thống, lỗ hổng hoặc chức năng. Đồng thời, kiến trúc tự thích ứng chung mà chúng tôi đề xuất cho phép tích hợp các phương pháp lập kế hoạch tấn công hiện có, bao gồm các phương pháp dựa trên lập kế hoạch AI và học tăng cường, trong các giai đoạn phân tích và lập kế hoạch, đây là một hướng đi cho các công việc trong tương lai.

Gần đây, một số công trình sử dụng LLM để tự động hóa thử nghiệm xâm nhập đã được đề xuất (Deng và cộng sự, 2024; Hilario và cộng sự, 2024), chứng minh thành công ban đầu trên các nghiên cứu điển hình về máy ảo (VM) đơn lẻ. Việc triển khai cụ thể của chúng tôi vượt trội hơn về số lượng dịch vụ được khai thác, thời gian chạy và khả năng mở rộng.

Chúng tôi tóm tắt các công trình liên quan và so sánh với triển khai tham chiếu của chúng tôi trong Bảng 1. Sự so sánh được trình bày trong bối cảnh khả năng của từng phương pháp để tự động hoàn thành bài kiểm tra thâm nhập trong môi trường thực tế. Trong bối cảnh đó, suy luận và ra quyết định trong thời gian chạy là rất cần thiết để xử lý các thay đổi động của hệ thống, chẳng hạn như các cuộc tấn công thất bại do những thay đổi hoặc sự không tin cậy trong môi trường (mạng) hoặc chính hệ thống mục tiêu, cũng như để thích ứng trong thời gian chạy để xử lý các biện pháp giảm thiểu có thể được triển khai hoặc khai thác các phương thức khai thác mới được phát hiện. Do đó, chúng tôi coi việc ra quyết định trong thời gian chạy là một tính năng bổ sung cho hai tính năng thiết yếu của tự động hóa tấn công và lập kế hoạch tấn công. Chúng tôi phân loại loại kiểm tra thâm nhập (Vats và cộng sự, 2020; Alhamed và Rahman, 2023) thành dựa trên hộp trắng, hộp xám và hộp đen. Một bài kiểm tra thâm nhập được coi là hộp đen khi không có thông tin trước đó về hệ thống mục tiêu hoặc các lỗ hổng của nó được sử dụng để huấn luyện các mô hình hoặc thực hiện kiểm tra thâm nhập. Ngược lại, kiểm tra thâm nhập hộp trắng yêu cầu thông tin đầy đủ về hệ thống và các lỗ hổng của nó. Kiểm thử xâm nhập hộp xám nằm giữa hai loại kia, trong đó thông tin một phần về hệ thống hoặc các lỗ hổng của hệ thống được sử dụng.

3. Phần mở đầu

Phần này đề cập đến các điều kiện tiên quyết cần thiết cho công việc này bao gồm mô hình kiến trúc bảo mật, hệ thống tự thích ứng và ra quyết định dựa trên tiện ích.

3.1. Mô hình kiến trúc cho bảo mật

Chúng tôi định nghĩa kiến trúc phần mềm là sự kết hợp của (i) các thành phần, (ii) các tương tác và (iii) các thuộc tính kiến trúc. Các thành phần chỉ định hành vi của từng phần riêng lẻ trong hệ thống. Mỗi thành phần bao gồm một tập hợp các giao diện có thể được gọi để cung cấp chức năng hệ thống được liên kết với chúng. Mỗi giao diện được liên kết với một tập hợp các khả năng. Khả năng là khả năng thực hiện một tập hợp các hành động nhất định trên một thành phần hoặc môi trường của nó. Các khả năng được sử dụng để cho phép tính linh hoạt trong việc mô tả các hiệu ứng của các hành động trong các hệ thống thuộc các miền khác nhau. Ví dụ về các khả năng bao gồm: gọi API từ xa, khởi tạo kết nối từ xa, thêm/xóa giao diện hoặc thành phần, tạo/mở/đóng tệp, chạy một tiến trình con, tạo luồng, v.v. Tương tác là việc gọi một hoặc nhiều Giao diện đích từ giao diện nguồn để hiện thực hóa chức năng tương ứng. Một thuộc tính kiến trúc biểu thị một phẩm chất quan trọng của một thành phần hoặc giao diện. Thuộc tính thành phần đề cập đến thông tin liên quan đến bảo mật liên quan đến toàn bộ thành phần mà không dành riêng cho một giao diện. Ví dụ: nếu chúng ta giả định rằng thành phần đại diện cho một máy chủ mạng, thì hệ điều hành hoặc địa chỉ IP của máy chủ sẽ cấu thành các thuộc tính đó. Tương tự, thuộc tính giao diện cấu thành thông tin dành riêng cho giao diện. Ví dụ: nếu giao diện đề cập đến một dịch vụ mạng, thuộc tính liên quan sẽ là cổng mà dịch vụ đó khả dụng; tương tự, nếu giao diện đề cập đến một tiến trình đang chạy, thuộc tính liên quan sẽ là mã định danh tiến trình.

Kiến trúc có tính bảo mật là một kiến trúc phần mềm có các thuộc tính liên quan đến thông tin bảo mật, bao gồm các lỗ hổng liên quan đến từng thành phần, các giao diện có thể được sử dụng để khai thác các lỗ hổng đó và cách các lỗ hổng có thể được kết hợp để tạo thành các cuộc tấn công phức tạp hơn, cho phép kẻ tấn công xâm phạm hệ thống. Chúng tôi coi lỗ hổng (Cook và cộng sự, 2018) là: ''Một lỗi, sai sót hoặc nhầm lẫn trong phần mềm máy tính cho phép hoặc gây ra hành vi không mong muốn''. Mượn định nghĩa khái niệm của các cỗ máy kỳ lạ (Dullien, 2020; Bratus và Shubina, 2017) và chuyển đổi khái niệm này sang kiến trúc có tính bảo mật, chúng tôi coi khai thác là: ''Đầu vào được tạo ra'' cho một giao diện dễ bị tấn công , gây ra hành vi không mong muốn do đối thủ kiểm soát''.

Định nghĩa 1. Chúng tôi định nghĩa một kiến trúc có thông tin bảo mật là một cặp tập hợp , , trong đó:

- một thành phần được định nghĩa là một bộ , trong đó: là tập hợp các giao diện được sử dụng để giao tiếp với các thành phần khác. Một giao diện là một bộ , trong đó: tham chiếu đến các khả năng đã thiết lập, tham chiếu đến tập hợp các lỗ hổng có thể rỗng và tham chiếu đến một tập hợp các thuộc tính kiến trúc liên quan đến bảo mật của . tham chiếu đến một tập hợp các thuộc tính kiến trúc liên quan đến bảo mật của . • là một tập hợp các tương tác thành phần. Một tương tác là một cặp (,) trong đó và là các giao diện nguồn và đích của sự tương tác.

Chúng tôi giả định rằng các tập giao diện của mỗi thành phần là rời rạc, do đó, chúng tôi định nghĩa: = là tập hợp tất cả các giao diện trong hệ thống. Tương tự, tập hợp các khả năng của mỗi giao diện được giả định là rời rạc. Do đó, chúng tôi định nghĩa là tập hợp tất cả các khả năng của hệ thống.

Trong bối cảnh kiến trúc chú trọng bảo mật, khả năng của một giao diện có thể được phân chia thành tập hợp các khả năng dự định (bởi nhà thiết kế và triển khai hệ thống) và tập hợp các khả năng không dự định. Tập hợp các khả năng không dự định có thể được phân chia thành: (i) tập hợp các khả năng không thể kiểm soát và tập hợp các khả năng có thể kiểm soát (lạ) của đối phương.

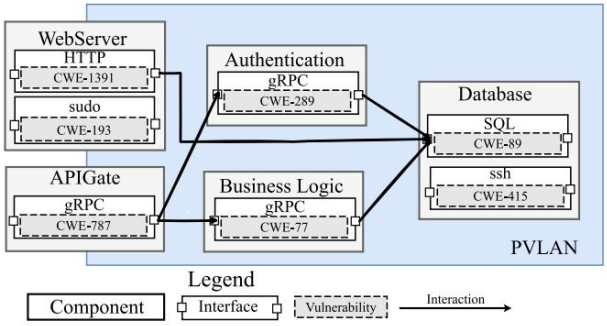
Nói cách khác, khi một giao diện được gọi, hành vi của nó được rút ra từ tập hợp các khả năng liên kết với giao diện đó . Có ba trường hợp có thể xảy ra cho hành vi của giao diện, được xác định bởi tính hợp lệ của nó đối với ý định thiết kế của hệ thống, tức là tùy thuộc vào việc khả năng đó có được thiết kế có chủ đích để trở thành một phần chức năng của hệ thống hay không. Ba trường hợp đó là:

- Nếu đầu vào hợp lệ (phù hợp với ý định thiết kế), thì giao diện sẽ hoạt động như mong muốn, tức là nó sẽ lấy chức năng của mình từ tập hợp các khả năng mong muốn.
- Nếu đầu vào không hợp lệ (không phù hợp với ý định thiết kế), nhưng dẫn giao diện đến hành vi ngoài ý muốn có thể bị kẻ tấn công kiểm soát, tức là khai thác, thì giao diện sẽ lấy chức năng của mình từ tập hợp các khả năng có thể bị kẻ tấn công kiểm soát,

Machine Translated by Google

Bảng 2
Ví dụ chạy các thực thể kiến trúc có thông tin bảo mật một phần.

Thành phần	Giao diện			Thuộc tính thành phần
	Khả năng	Điểm yếu	Giao diện của cải	
Máy chủ web	ServeHttp Chạy với tư cách là người dùng khác	CWE-1391 CWE-193	Cổng:80 PID:6066	IP:10.0.0.1
Cổng API Xác thực Logic kinh doanh	DelegategRPC Người dùng xác thực DoWork	CWE-787 CWE-289 CWE-77	Cổng: 9901 Cổng: 5105 Cổng: 5104	IP:10.0.0.2 IP:10.0.0.3 IP:10.0.0.4
Cơ sở dữ liệu	Xử lý SQL Truy cập từ xa	CWE-89 CWE-415	Cổng: 3306 Cổng: 22	IP:10.0.0.5



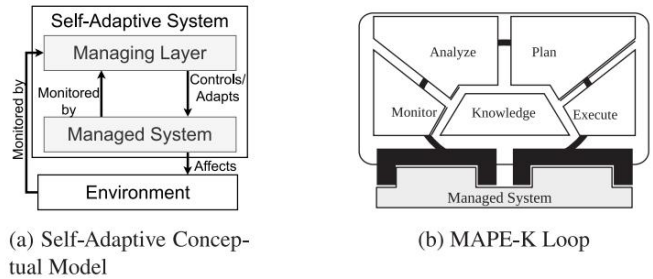
Hình 1. Một ví dụ về kiến trúc chú trọng bảo mật.

- Nếu đầu vào không hợp lệ và không thể kiểm soát, hành vi giao diện không đủ tin cậy để được sử dụng trong một cuộc khai thác, ví dụ, nó có thể dẫn đến đến một sự cố hoặc một trạng thái lỗi không phải do đối thủ mong muốn. giao diện rút ra chức năng của nó từ tập hợp các thành phần không thể kiểm soát khả năng.

Ví dụ thực tế. Hình 1 minh họa một kiến trúc bảo mật. Kiến trúc này bao gồm 5 thành phần: WebServer, APIGate, Authentication, Business Logic và Database. Mỗi thành phần có một số
các giao diện dễ bị tấn công cũng được hiển thị trong hình. Bảng 2, trong ngoài việc hiển thị các giao diện dễ bị tấn công, còn cung cấp một ví dụ khả năng, thuộc tính giao diện và thuộc tính thành phần cho mỗi thành phần. Các thành phần Webserver và APIGate được đưa lên Internet, và tất cả các thành phần được kết nối trong một mạng LAN ảo riêng. Hệ thống mô hình hóa một kiến trúc web quy mô nhỏ. Máy chủ web hoạt động với tư cách là lớp trình bày, trong khi APIGate kết hợp với các dịch vụ vi mô Au-thentication và Business Logic cung cấp ứng dụng lớp, nhu cầu lưu trữ của lớp được đáp ứng bởi cơ sở dữ liệu.

3.2. Hệ thống tự thích ứng

Một hệ thống tự thích ứng là một hệ thống phần mềm có thể động và tự động thay đổi kiến trúc hoặc hành vi của nó tại thời điểm chạy để đạt được các mục tiêu của bên liên quan và các phẩm chất ngoài chức năng một cách hiệu quả hơn (Cheng và cộng sự, 2009). Một hệ thống tự thích ứng cũng có thể tự thích nghi để thích ứng với những thay đổi trong bối cảnh hoặc môi trường của nó. Kiến trúc hệ thống tự thích nghi thường bao gồm ba yếu tố cơ bản các yếu tố (Weyns, 2019): (i) môi trường, (ii) hệ thống được quản lý và (iii) hệ thống quản lý. Hệ thống quản lý kiểm soát hệ thống được quản lý và chứa logic thích ứng cần thiết để đạt được mục tiêu thích ứng. Hệ thống quản lý giám sát cả môi trường và hệ thống được quản lý và điều chỉnh hệ thống được quản lý khi cần thiết. để tiến tới các mục tiêu thích ứng của nó. Môi trường chứa mảnh vỡ của thế giới bên ngoài tương tác với, và kết quả là, ảnh hưởng và bị ảnh hưởng bởi hoạt động của hệ thống (Jackson, 1997). Mục tiêu thích ứng là mối quan tâm của hệ thống quản lý đối với



(a) Self-Adaptive Conceptual Model (b) MAPE-K Loop

Hình 2. Thiết lập hệ thống tự thích ứng điển hình và triển khai MAPE-K của lớp quản lý.

hệ thống được quản lý, tức là trạng thái mong muốn mà hệ thống được quản lý phải đạt được trong, hoặc một thuộc tính mong muốn mà nó phải đáp ứng để đáp ứng hoặc tiến triển hướng tới mục tiêu của nó. Hình 2(a) cho thấy một mô hình khái niệm về khả năng tự thích ứng hệ thống và sự tương tác của nó với môi trường xung quanh.

Khối xây dựng chính của một hệ thống quản lý là một hệ thống tự chủ người quản lý (Kephart và Chess, 2003), còn được gọi là vòng lặp MAPE-K, bao gồm bốn giai đoạn: Giám sát, Phân tích, Lập kế hoạch và Thực hiện. Cả bốn giai đoạn đều chia sẻ một Cơ sở kiến thức chung. Giám sát giai đoạn thu thập dữ liệu từ hệ thống được quản lý và môi trường, và cập nhật thông tin được lưu trữ trong Cơ sở kiến thức với cái nhìn cập nhật về thế giới. Giai đoạn Phân tích khai thác cái nhìn cập nhật thông tin được lưu trữ trong Cơ sở kiến thức để xác định xem một cần phải thích ứng. Khi một sự thích ứng được kích hoạt, Kế hoạch giai đoạn xây dựng một kế hoạch bằng cách kết hợp một tập hợp các hành động thích ứng để đáp ứng các mục tiêu thích ứng. Kế hoạch thích ứng được thực hiện bởi Giai đoạn thực hiện thực hiện các thay đổi cần thiết cho mục được quản lý hệ thống. Kiến trúc vòng lặp MAPE-K được thể hiện trong Hình 2(b).

3.3. Ra quyết định dựa trên tiện ích

Trong việc ra quyết định dựa trên tiện ích đa thuộc tính (von Neumann và Morgenstern, 1947; Anand, 1995), một quyết định là sự lựa chọn của một trong số một tập hợp các tùy chọn chịu ảnh hưởng của một số thuộc tính hoặc yếu tố liên quan đến từng lựa chọn. Một yếu tố, đề cập đến mối quan tâm rằng ảnh hưởng đến quyết định. Hàm ( ) trả về giá trị của một tùy chọn liên quan đến một yếu tố, nghĩa là, nó đánh giá mức độ nào đóng góp tích cực vào việc được lựa chọn nếu là người duy nhất yếu tố được xem xét. Hàm ( ) trả về giá trị tương ứng được chuẩn hóa. Các yếu tố được gán các mức độ quan trọng khác nhau cho bằng một tập hợp các trọng số, tổng cộng bằng 1, tức là = 1. Nếu các yếu tố không phụ thuộc vào phép cộng (Keeney và Raiffa, 1993), sau đó mỗi yếu tố và được đánh giá độc lập và tổng trọng số của chúng là kết quả tiện ích của một quyền chọn. Do đó, tiện ích của một quyền chọn, cho một tập hợp các yếu tố độc lập cộng gộp , sau đó được định nghĩa là:

( ) = ( ) (1)

Để đưa ra quyết định bằng cách sử dụng lý thuyết quyết định đa thuộc tính, có năm bước được thực hiện (Jansen, 2011).

Machine Translated by Google

Bảng 3
Các phương pháp kiểm tra xâm nhập tự động.

Tiếp cận	Hệ thống chuyển tiếp	Cơ sở chiến lược
Lập kế hoạch AI	Chuyển đổi được gắn nhãn hệ thống	Tìm kiếm theo phương pháp heuristic, Kế hoạch thời gian, Giải quyết POMDP
Không có mô hình học tăng cường	Trạng thái hữu hạn máy móc	Q-Học tập, Học sâu Q
Công việc này	Chuyển đổi được gắn nhãn hệ thống	Máy tính tự động, Dựa trên tiện ích Lý thuyết quyết định

a Một quy trình quyết định Markov có thể quan sát được một phần có thể được biểu diễn bằng LTS mã hóa quan sát, xác suất và phần thưởng thông qua việc dán nhãn chức năng.
b Quá trình quyết định Markov với phần thưởng và xác suất chưa biết là một máy trạng thái hữu hạn có thể được biểu diễn dưới dạng LTS hạn chế.

1. Các lựa chọn có liên quan và các yếu tố quan trọng được xác định,
2. Đối với mỗi yếu tố, một hàm giá trị và hàm giá trị chuẩn hóa tương ứng được xác định,
3. Các yếu tố được xếp hạng và trọng số của chúng được xác định,
4. Tiện ích cho mỗi lựa chọn được tính theo Công thức (1),
5. Lựa chọn có tiện ích cao nhất được chọn

4. Xây dựng vấn đề

Chúng tôi giả định rằng hệ thống được thử nghiệm thâm nhập được mô hình hóa như một kiến trúc được thông báo về bảo mật mà ban đầu không được biết đến kiểm tra thâm nhập. Chúng tôi gọi hệ thống đó và kiến trúc của nó là hệ thống mục tiêu hoặc kiến trúc mục tiêu trong phần còn lại của bài báo này. Chúng tôi định nghĩa thử nghiệm thâm nhập là quá trình mà người thử nghiệm thâm nhập cố gắng khám phá càng nhiều kiến trúc hệ thống mục tiêu và có được càng nhiều khả năng của nó càng tốt.

Khả năng thường cấp thêm/tăng thêm đặc quyền hoặc cung cấp có nghĩa là chức năng không mong muốn, ví dụ, bằng cách lấy mã từ xa khả năng thực thi trên một thành phần, tuy nhiên, khả năng cũng có thể bao gồm các hành động có thể dẫn đến việc giảm mức độ dịch vụ của hệ thống, ví dụ, khi người kiểm tra xâm nhập nhận được thông báo từ chối dịch vụ hoặc tương tự khả năng. Trong công việc này, với mục tiêu đã nêu, người kiểm tra thâm nhập sẽ chỉ sử dụng những khả năng như vậy nếu chúng có thể được sử dụng để mở rộng hơn nữa kiến thức của họ về hệ thống, ví dụ, tìm hiểu về các biện pháp đối phó hoặc để mở rộng hơn nữa năng lực đã đạt được của họ.

Mục đích của phần này là cung cấp một công thức vấn đề thống nhất điều đó độc lập với miền giải pháp và đủ sức biểu đạt để bao gồm các cách tiếp cận mà chúng tôi đã thảo luận trong phần công việc liên quan của chúng tôi, trong bổ sung vào kiến trúc chung và triển khai cụ thể chúng tôi đề xuất trong Phần 5. Hai yếu tố chính của công thức vấn đề của chúng tôi trong phần này là một hệ thống chuyển đổi có nhãn (van Glabbeek, 2001) (LTS) và một chiến lược trò chơi (Kwiatkowska, 2016). Theo trực giác, LTS xác định không gian hành động trong khi chiến lược xác định cách giải quyết cách tiếp cận. Bảng 3 đưa ra sự so sánh giữa các cách tiếp cận khác nhau. Phân loại bảng dựa trên miền mà từ đó các kỹ thuật giải pháp được chiến lược sử dụng được rút ra. Giải pháp lập kế hoạch AI, cụ thể là Giải quyết POMDP, tìm kiếm theo phương pháp kinh nghiệm và lập kế hoạch thời gian mang lại kết quả tối ưu giải pháp cho một vấn đề thường được mô tả là một vấn đề lập kế hoạch cổ điển. Các chiến lược học tăng cường mà chúng tôi liệt kê thường đưa ra các giải pháp gần đúng không thể đảm bảo tính tối ưu nhưng thường mở rộng đến không gian trạng thái lớn hơn.

Trong phần còn lại của phần này, trước tiên chúng ta chính thức hóa các yếu tố cấu thành được yêu cầu phải chính thức thể hiện vấn đề kiểm tra thâm nhập và sau đó dựa trên những định nghĩa đó để chỉ định thử nghiệm thâm nhập ở cấp độ kiến trúc.

4.1. Trạng thái kiểm tra thâm nhập, các cuộc tấn công và quét

Người kiểm tra thâm nhập đưa ra quyết định dựa trên kiến thức hiện tại của cô ấy về kiến trúc hệ thống mục tiêu và khả năng hiện tại của cô ấy. Để để đạt được mục tiêu của mình, người kiểm tra xâm nhập thực hiện các cuộc tấn công và quét nhằm mục tiêu vào các thành phần hệ thống mục tiêu.

Định nghĩa 2. Cho một kiến trúc hệ thống mục tiêu, được mô hình hóa như một kiến trúc được thông báo về bảo mật = , , trạng thái kiểm tra thâm nhập là một bộ = , , trong đó:

- , tập hợp các khả năng của người kiểm tra thâm nhập,
- , tập hợp các thành phần mà trình kiểm tra thâm nhập có kiến thức về,
- , tập hợp các giao diện mà trình kiểm tra thâm nhập có kiến thức về

Khả năng của người kiểm tra thâm nhập đề cập đến các hành động mà người kiểm tra thâm nhập có thể thực hiện để tác động đến hệ thống, có thể là lành tính và ác ý. Chúng tôi coi những hành động lành tính là những hành động không lành tính nhất thiết dẫn đến sự thỏa hiệp thành phần và mức độ nguy hiểm của nó phụ thuộc vào ngữ cảnh. Ví dụ về các khả năng đó bao gồm: liệt kê các tiến trình đang chạy của một hệ thống, mở một cổng mới hoặc tạo một người dùng mới. Ngược lại, hành động độc hại là những hành động có mục đích rõ ràng tại sự xâm phạm hệ thống. Ví dụ về các hành động như vậy bao gồm, khai thác lỗ hổng hỏng bộ nhớ, chạy phần mềm bẻ khóa mật khẩu, v.v. Trong bối cảnh này, kiến thức về một thành phần đề cập đến việc biết rằng thành phần là một phần của hệ thống mục tiêu, trong khi kiến thức về giao diện đề cập đến việc biết rằng giao diện là một phần của hệ thống ngoài ra một số thông tin bổ sung có thể mô tả giao diện.

Ví dụ, khi người kiểm tra thâm nhập ban đầu phát hiện ra Thành phần cơ sở dữ liệu trong ví dụ đang chạy, cô ấy chỉ có kiến thức về giao diện SQL. Tuy nhiên, một khi lỗ hổng SQL injection được sử dụng để tải lên một shell từ xa, trình kiểm tra xâm nhập có thể liệt kê các dịch vụ đang chạy trên thành phần Cơ sở dữ liệu và tìm hiểu về giao diện ssh dễ bị tấn công cũng nằm trong cùng một thành phần.

Người kiểm tra thâm nhập có thể mở rộng khả năng của mình bằng cách thực hiện các cuộc tấn công và các thành phần và giao diện hiện được biết đến của cô ấy bằng cách thực hiện quét. Một cuộc tấn công đề cập đến một chuỗi các bước tấn công có thể liên quan đến việc khai thác các lỗ hổng trong giao diện của một thành phần điều này dẫn đến việc người kiểm tra thâm nhập có được những khả năng mới. A quét tương ứng với một loạt các hành động dẫn đến sự thâm nhập người kiểm tra mở rộng kiến thức của họ về các thành phần của hệ thống mục tiêu hoặc giao diện.

Định nghĩa 3. Cho một kiến trúc được thông báo về bảo mật = , và trạng thái kiểm tra thâm nhập = , , , một cuộc tấn công là một chuỗi các cuộc tấn công các bước. Một bước tấn công là một bộ = , , 0 , + trong đó:

- = , , là sự tương tác, bị giới hạn bởi nguồn và giao diện mục tiêu và gọi chức,năng cần thiết để tạo điều kiện cho bước tấn công,
- , là tập hợp các lỗ hổng (có thể là trống),
- 0là tập hợp các khả năng tiên quyết mà sự thâm nhập người kiểm tra phải có bước tấn công mới có thể thực hiện được,
- là tập hợp các khả năng đạt được bởi người kiểm tra thâm nhập khi bước tấn công thành công.

Sau khi một bước tấn công thành công, khả năng kiểm tra xâm nhập sẽ được cập nhật như sau: = +. Trong trường hợp đó, người kiểm tra thâm nhập,

Machine Translated by Google

Bảng 4
Khái niệm và bộ cập nhật trạng thái kiểm tra xâm nhập.

Ý tưởng	Hệ thống mục tiêu Trạng thái kiểm tra thâm nhập Kết quả quét/tấn công	Điều kiện tiên quyết
Khả năng	+ .	0
Thành phần	+	–
Giao diện	+	–

ngoài việc đạt được một tập hợp con các khả năng được cung cấp bởi giao diện , có thể đạt được các khả năng không liên quan đến giao diện riêng của nó. Đối với Ví dụ, một người kiểm tra thâm nhập có thể có được khả năng truy cập vào một lưu trữ trong mạng bằng cách vô hiệu hóa quy tắc tường lửa. Chúng tôi đánh dấu tập hợp khả năng đạt được bằng cách thực hiện một cuộc tấn công với +, Ở đâu = + .

Định nghĩa 4. Cho một kiến trúc và trạng thái quét thử nghiệm thâm nhập , Một là một bộ = 0 , +, + trong đó:

- 0 , tập hợp các khả năng tiên quyết mà sự thâm nhập người kiểm tra phải giữ để thực hiện quét,
- + , tập hợp các thành phần được xác định bằng cách quét,
- + , tập hợp các giao diện được xác định bởi quá trình quét

Sau khi quét hoàn tất, trạng thái kiểm tra thâm nhập được cập nhật như sau: = phản ánh sự cập nhật của sự thâm nhập kiến thức của người kiểm tra.

Bảng 4 cung cấp tổng quan về các tập hợp và tập con có liên quan trong khi chạy quét hoặc thực hiện một cuộc tấn công và cập nhật sự xâm nhập trạng thái kiểm tra theo kết quả. Cột đầu tiên đề cập đến tập hợp tất cả các yếu tố của một khái niệm trong hệ thống mục tiêu. Cột thứ hai đề cập đến các yếu tố của một khái niệm là một phần của trạng thái thử nghiệm thâm nhập. cột thứ ba liệt kê các yếu tố được thêm vào thử nghiệm thâm nhập trạng thái khi một cuộc tấn công hoặc một lần quét thành công. Thành công trong một cuộc tấn công sẽ thêm khả năng kiểm thử thâm nhập (+), trong khi thành công trong một bài kiểm tra bổ sung kiến thức của các thành phần (+) và giao diện (+). Cột cuối cùng hiển thị điều kiện tiên quyết cho một cuộc tấn công hoặc quét là khả năng(0).

4.2. Công thức thử nghiệm thâm nhập

Hai hình thức trung tâm của tác phẩm này bao gồm: định nghĩa về vấn đề kiểm tra thâm nhập và định nghĩa về chiến lược để hướng dẫn hành động kiểm tra xâm nhập.

Định nghĩa 5. Với các định nghĩa cho hệ thống mục tiêu, trạng thái kiểm tra thâm nhập, các cuộc tấn công và quét, một cuộc kiểm tra thâm nhập có thể được định nghĩa chính thức được định nghĩa là một hệ thống chuyển tiếp được dán nhãn (van Glabbeek, 2001), = , , , , 0 , trong đó:

- là một tập hợp các trạng thái kiểm tra thâm nhập. Một trạng thái được định nghĩa bởi Định nghĩa 2,
- là một tập hợp các cuộc tấn công. Một cuộc tấn công được định nghĩa bởi Định nghĩa 3.
- là một tập hợp các phép quét. Một phép quét được định nghĩa bởi Định nghĩa 4,
- × × là một mối quan hệ chuyển tiếp mô hình hóa sự thâm nhập hành động kiểm tra, chúng tôi viết:
  - ′, khi hành động được chọn là một cuộc tấn công,
  - ′, khi hành động được chọn là quét,
- 0 là trạng thái thâm nhập ban đầu,
- là một tập hợp các trạng thái kết thúc.

Chúng tôi định nghĩa chiến lược kiểm tra thâm nhập là một bộ, , = ′ 0′ trong đó:

- là một tập hợp hữu hạn các phần tử bộ nhớ,
- 0 là ánh xạ bộ nhớ ban đầu,
- × là một hàm cập nhật bộ nhớ, trong đó (trả về nội dung ,) được cập nhật của trạng thái hiện tại đã cho ,
- × là hàm di chuyển tiếp theo, trả về bước tiếp theo được thực hiện dựa trên trạng thái thử nghiệm thâm nhập hiện tại và nội dung bộ nhớ.

Một chiến lược tạo ra một đường chuyển tiếp (có thể vô hạn) bắt đầu ở trạng thái và kết thúc ở bằng cách áp dụng lặp đi lặp lại theo sau là . Mỗi ứng dụng như vậy tạo ra quá trình chuyển đổi tiếp theo được đưa vào . Theo trực giác, một chiến lược kiểm tra thâm nhập là thành công nếu nó dẫn đến một trong các trạng thái cuối cùng trong trong một phạm vi hữu hạn số bước, tức là nếu bắt đầu từ 0 và áp dụng một số lần hữu hạn sẽ dẫn đến trạng thái 0 .

Các bài kiểm tra thâm nhập có thể có nhiều mục tiêu. Trong công thức của chúng tôi, chúng tôi mô hình hóa một mục tiêu như một vị ngữ giữ nguyên trạng thái kết thúc trong . Vị ngữ có thể bao gồm bất kỳ yếu tố nào của thử nghiệm thâm nhập trạng thái, bao gồm các đặc tính kiến trúc của các thành phần và giao diện.

Tuy nhiên, mục tiêu điển hình là khám phá càng nhiều hệ thống càng tốt có thể và giành quyền kiểm soát càng nhiều hệ thống càng tốt. Điều này mục tiêu được chính thức hóa như sau:

¬ + (2)

¬ + (3)

¬ + (4)

Nói cách khác, phương trình (2) có nghĩa là không còn cuộc tấn công nào nữa sẽ tăng khả năng của người kiểm tra thâm nhập nếu thành công. Tương tự như vậy, Các phương trình (3) và (4) có nghĩa là không nên có bất kỳ bản quét nào còn lại cho phép người kiểm tra xâm nhập để tìm hiểu về một thành phần hoặc giao diện mới.

4.3. RL và PDDL cho định nghĩa vấn đề của chúng tôi

Công thức học tăng cường. Công trình liên quan gần nhất với chúng tôi sử dụng học tăng cường để đạt được thử nghiệm thâm nhập hộp đen (Zhou và cộng sự, 2019). Chúng tôi trình bày một cách không chính thức cách chuyển đổi nó công thức của vấn đề kiểm tra thâm nhập vào công thức của chúng tôi. Bản đồ chính xác được đưa ra trong Phụ lục. Các công trình liên quan khác sử dụng phương pháp học tăng cường, ví dụ, Chowdhary et al. (2020), Hu et al. (2020) và Zhou et al. (2021) có thể được lập bản đồ sau một quá trình tương tự. Trong Zhou et al. (2019), một thử nghiệm thâm nhập được đưa ra bằng một quá trình quyết định Markov (Puterman, 2014). Không gian trạng thái là được mô tả bởi một số máy. Một máy được xác định bởi một định danh, hệ điều hành của nó, một tập hợp các cổng mở, một tập hợp các cổng đã biết dịch vụ và trạng thái khai thác của nó. Không gian hành động tương ứng với một Một tập hợp các lần quét và một tập hợp các cuộc tấn công. Giống như học tăng cường thông thường, mỗi hành động đều có một xác suất và một phần thưởng. Sự tương ứng với công thức của chúng tôi như sau: (i) mỗi máy tương ứng với một thành phần có hệ điều hành và khai thác của nó trạng thái là các thuộc tính thành phần, (ii) mỗi cổng mở tương ứng với một giao diện với các dịch vụ đã biết là các thuộc tính giao diện, (iii) quét và các cuộc tấn công tạo nên các cuộc quét và tấn công của chúng tôi với sự khác biệt duy nhất là mô hình trong Zhou et al. (2019) chỉ hỗ trợ các cuộc tấn công một bước và (iv) các xác suất hành động và phần thưởng tạo nên các yếu tố bộ nhớ của một chiến lược.

Các hình thức PDDL. Các công thức dựa trên PDDL cũng dễ dàng được lập bản đồ với tuyên bố vấn đề của chúng tôi. Ví dụ, chúng tôi chỉ ra cách công thức dựa trên PDDL trong Obes et al. (2013) có thể được ánh xạ không chính thức vào định nghĩa. Obes et al. (2013) định nghĩa một kế hoạch AI-thời gian cổ điển vấn đề (Fox và Long, 2003). Các yếu tố chính của nó là: (i) các vị từ rằng tương ứng với tài sản và tính chất của chúng, (ii) các hành động tương ứng đối với các hành động khai thác, tức là các cuộc tấn công và (iii) một mục tiêu tương ứng đến một tập hợp các vị từ thỏa mãn ở cuối kế hoạch. Việc lập bản đồ định nghĩa vấn đề của chúng tôi là đơn giản dựa trên những điều sau đây quan sát: mỗi vị ngữ đề cập đến một máy chủ hoặc một cổng và do đó có thể được ánh xạ tới một thuộc tính thành phần hoặc giao diện trong công thức của chúng tôi. Các hành động khai thác cũng có thể được ánh xạ trực tiếp tới các cuộc tấn công trong

Machine Translated by Google

mô hình, bằng cách ánh xạ các điều kiện tiên quyết của chúng vào tập hợp các khả năng cần thiết của mỗi cuộc tấn công và tác động của chúng vào tập hợp các khả năng đạt được θ +. Mục tiêu có thể được ánh xạ trực tiếp đến mục tiêu của chúng ta sau các vị ngữ và các hành động đã được dịch. Lưu ý rằng Obes et al. (2013) là một phương pháp thử nghiệm thâm nhập hộp trắng, do đó các tập hợp các thành phần và giao diện được coi là đã biết tức là chúng được đưa ra theo định nghĩa vấn đề. Hai chiến lược giải quyết liên quan đến các nhà lập kế hoạch kệ, cụ thể là metric-FF (Hoffmann, 2002) và SGPlan (Chen et al., 2006), cả hai đều chủ yếu là những người lập kế hoạch tìm kiếm hướng tới sử dụng phương pháp tìm kiếm. SGPlan ngoài phương pháp tìm kiếm còn sử dụng một vấn đề phương pháp phân tích.

5. Kiểm tra thâm nhập tự động dựa trên kiến trúc

Trong phần này chúng tôi trình bày một hệ thống tự thích ứng chung, tức là kiến trúc và thuật toán cấp cao cần thiết để tự động hóa thử nghiệm thâm nhập như được định nghĩa trong Phần 4. Đầu tiên, chúng ta thảo luận về từng sự thích ứng và sự liên hệ của nó với các yếu tố của phần trước. Phần sau đây mô tả các quyết định cụ thể được đưa ra trong triển khai thử nghiệm thâm nhập tự động theo kiến trúc (ADAPT), khai thác lý thuyết tiện ích để đưa ra quyết định.

5.1. Tổng quan và cơ sở lý luận

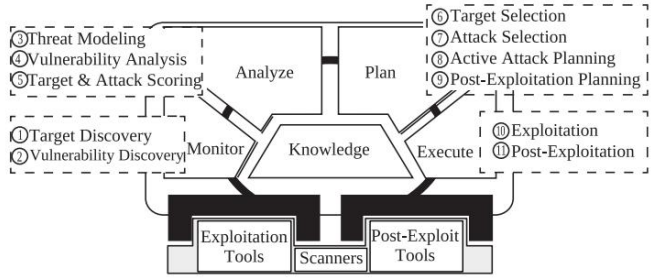
Cách tiếp cận này là một cách tiếp cận theo hướng hộp đen, hướng đến kiến trúc cảm giác rằng hệ thống bắt đầu hoạt động của nó với một kiến trúc mục tiêu trống rỗng và không có thông tin nào về nó và dần dần xây dựng một mô hình nội bộ của kiến trúc được thông báo về bảo mật của hệ thống mục tiêu được sử dụng để lý luận về thành phần nào đã biết và giao diện để tấn công tiếp theo và quét nào để thực hiện để mở rộng mô hình nội bộ để bao gồm nhiều thành phần và giao diện được khám phá hơn. Cách tiếp cận này cũng có thể hoạt động trong cài đặt hộp xám hoặc hộp trắng khi thông tin một phần hoặc tương ứng đầy đủ về mục tiêu kiến trúc được cung cấp như một kiến trúc ban đầu có tính bảo mật.

Chúng tôi đã chọn sử dụng hệ thống tự thích ứng như một giải pháp để tích hợp lập kế hoạch tấn công và tự động hóa tấn công vì khả năng tự thích ứng các hệ thống được biết là có hiệu quả trong việc tự động hóa nhiệm vụ (Weyns, 2018) và việc ra quyết định năng động trong môi trường không chắc chắn (Cali-nescu và cộng sự, 2020). Hơn nữa, kiến trúc tự chủ là một sự phù hợp tự nhiên để tích hợp lập kế hoạch tấn công và tự động hóa tấn công vì nó cung cấp một sự phân tách rõ ràng các mối quan tâm giữa việc ra quyết định, tức là, tấn công phần lập kế hoạch và phần tự động hóa tấn công có thể được tách biệt rõ ràng vào hệ thống quản lý và điều hành.

Kiến trúc chung được thể hiện trong Hình 3. Hệ thống con quản lý hoạt động như một công cụ ra quyết định hướng dẫn quá trình kiểm tra xâm nhập trong khi hệ thống con được quản lý có thể cấu hình lại. và cung cấp các công cụ cần thiết để thực hiện các quyết định được đưa ra bởi hệ thống quản lý. Hệ thống được quản lý bao gồm một bộ máy quét, kiểm tra xâm nhập và tự động hóa tấn công, và sau khi khai thác các công cụ được cấu hình, phối hợp và kiểm soát bởi người quản lý hệ thống con được triển khai như một trình quản lý tự động với Kiến trúc MAPE-K tiêu chuẩn. Các công cụ tạo nên hệ thống được quản lý hệ thống có thể được vận hành đồng thời, tức là, nhiều lần quét, tấn công và các hoạt động khai thác sau có thể được thực hiện bất cứ lúc nào. Khi quét chấm dứt thành phần giám sát được thông báo bởi một sự kiện dựa trên gọi lại. Tương tự như vậy, thành phần thực thi được thông báo thông qua một gọi lại khi hành động khai thác hoặc hậu khai thác kết thúc.

5.2. Thiết kế phần tử MAPE-K

Cơ sở tri thức. Cơ sở tri thức hoạt động như một nơi cung cấp thông tin cần thiết khi chạy để triển khai và hỗ trợ các pha của vòng lặp MAPE-K. Nó lưu trữ thông tin bao gồm: trạng thái kiểm tra xâm nhập, các danh mục tấn công và quét và chiến lược để hướng dẫn lựa chọn tấn công và quét. Về mặt hình thức, cơ sở kiến thức



Hình 3. Kiến trúc kiểm tra xâm nhập tự động.

Bảng 5
Các khái niệm và tập hợp cơ sở kiến thức.

Ý tưởng	Bộ	Yếu tố	Tích cực	Thành công/Bị khai thác	Thất bại
Thành phần					–
Tấn công					
Quét					–

có thể được định nghĩa, bằng cách sử dụng các phần tử được trình bày trong Phần 4, như một bộ: = , , , .

Cơ sở kiến thức chứa thông tin bao gồm trạng thái kiểm tra xâm nhập, tức là phần của kiến trúc được thông báo về bảo mật, đã được phát hiện. Số lượng các danh mục tấn công và quét một tập hợp các chiến thuật tấn công và một tập hợp các kỹ thuật quét. Trong tài liệu tham khảo theo Định nghĩa 5, kho tấn công tương ứng với và quét tiết mục tương ứng với . Một chiến thuật tấn công là một chuỗi các cuộc tấn công kỹ thuật, mỗi kỹ thuật là một khuôn mẫu tấn công và có thể được thực hiện bằng cách chỉ định các thông số cụ thể cần thiết. Ví dụ, để thực hiện một kỹ thuật tấn công cố gắng bẻ khóa mật khẩu yếu nằm trong thành phần WebServer của ví dụ đang chạy trong Hình 1, chúng ta cần chỉ định: (i) một công cụ bẻ khóa biểu mẫu http tương ứng, (ii) Địa chỉ IP và cổng của giao diện HTTP của WebServer và (iii) biểu mẫu mục tiêu. Tương tự như các kỹ thuật tấn công, các kỹ thuật quét tương ứng với quét các mẫu cần được thực hiện bằng cách cung cấp một tập hợp các tham số. Các kỹ thuật tấn công được thực hiện bằng cách chạy các công cụ khai thác trong khi quét các kỹ thuật được thực hiện bằng cách chạy máy quét, ví dụ, mạng hoặc công cụ quét lỗ hổng hoặc công cụ hậu khai thác, ví dụ: công cụ phát hiện thông tin xác thực hoặc quy trình. Bảng 5 hiển thị tổng quan về các tập hợp và tập hợp con mà cơ sở kiến thức duy trì để theo dõi cuộc tấn công và quét lịch sử thực thi và trạng thái khai thác của từng thành phần. Lưu ý rằng , và là các tập hợp rời rạc và { } là tập hợp của các cuộc tấn công có sẵn có thể được chọn để thử tiếp theo. Tương tự như vậy, và không giao nhau và { } là tập hợp các lần quét từ đó lần quét tiếp theo sẽ được chọn từ và { } là tập hợp của các thành phần mà thành phần mục tiêu tiếp theo có thể được chọn từ đó.

Giám sát. Giai đoạn giám sát có trách nhiệm cập nhật kiến thức của kiến trúc về mặt mục tiêu (các thành phần có thể bị tấn công) và các cuộc tấn công có thể xảy ra (hoặc các lỗ hổng chưa biết trước đây hoặc các giao diện dễ bị tấn công trước đây). Đặc biệt, giai đoạn giám sát sử dụng hai loại đầu dò: (i) đầu dò từ xa (ii) và các đầu dò cục bộ. Các đầu dò từ xa được triển khai trong hệ thống được quản lý và thực hiện quét từ xa thông qua mạng, trong khi các đầu dò cục bộ được được cài đặt vào các thành phần mục tiêu sau khi chúng bị xâm phạm và thực hiện cả quét cục bộ và từ xa. Quét cục bộ tương đương với quét thành phần để tìm các giao diện không nhất thiết phải được hiển thị hoặc có thể truy cập vào hệ thống được quản lý, trong khi số lượng quét từ xa để quét từ xa thông qua thành phần bị xâm phạm để truy cập các mạng mà hệ thống được quản lý không phải là một phần của. Liên quan đến Định nghĩa 5, giai đoạn giám sát cập nhật trạng thái kiểm tra thâm nhập , dựa trên các thành phần hoặc giao diện mới được phát hiện của mục tiêu kiến trúc . Việc thực hiện cấp cao của giai đoạn giám sát là được hiển thị trong Giai đoạn thích ứng 1: Giám sát. monitor_run chịu trách nhiệm

Machine Translated by Google

để bắt đầu một giai đoạn giám sát mới, nó nhận được một bộ quét mới để được thực hiện, thêm mỗi lần quét vào tập hợp các lần quét đang hoạt động (dòng 3) và bắt đầu mỗi lần quét theo thứ tự (dòng 4). Khi một lần quét hoàn tất, monitor_control được gọi: đầu tiên, các tập hợp các lần quét đang hoạt động và đã hoàn thành được cập nhật (dòng 8 và 9), thứ hai, trạng thái kiểm tra thâm nhập được cập nhật với kết quả quét (dòng 10 và 11) và cuối cùng là giai đoạn phân tích mới được gọi nếu có một lần quét chưa được thực hiện hoặc một người đang chạy, hoặc tồn tại một cuộc tấn công chưa được thử hoặc một người đang chạy. (dòng 12–14).

Giai đoạn thích ứng 1: Giám sát

```
1 Hàm monitor_run( , )
      Đầu vào: Tập hợp các lần quét sẽ được bắt đầu
      Đầu vào: Cơ sở kiến thức = , , ,
2     cho làm
          // Thêm quét vào các lần quét đang hoạt động và bắt đầu quét
3             = { }
4         quét_bắt_đầu( )
5 kết thúc
6 kết thúc
7 Hàm monitor_control( , )
      Đầu vào: Một lần quét hoàn tất
      Đầu vào: Cơ sở kiến thức = , , ,
      // Cập nhật các lần quét đang hoạt động và đã hoàn thành
8         = { }
9         = { }
      // Cập nhật trạng thái kiểm tra thâm nhập với kết quả quét
10        = +
11        = +
      // Đang chạy quét hoặc có sẵn hoặc đang tấn công hoặc
          chưa được thử
12    nếu
13                    ( ) thì
14        phân tích_chạy( )
15 kết thúc
16 kết thúc
```

Phân tích. Giai đoạn phân tích chịu trách nhiệm lập mô hình tấn công và phân tích lỗ hổng. Một mô hình tấn công được xây dựng và duy trì ngày dựa trên kết quả của giai đoạn giám sát. Mô hình tấn công là sau đó được sử dụng để phân tích lỗ hổng đánh giá mức độ dễ bị tổn thương mỗi thành phần và giao diện được ước tính là và bổ sung thực hiện ưu tiên tấn công để lọc ra các cuộc tấn công không khả thi cho trạng thái đã biết của hệ thống mục tiêu và xếp hạng các hệ thống có sẵn các cuộc tấn công dựa trên khả năng hiệu quả của chúng. Kết quả của Phân tích lỗ hổng là mục tiêu và thứ hạng tấn công. Cuộc tấn công mô hình, mục tiêu và thứ hạng tấn công tạo nên các yếu tố bộ nhớ của . Những bảng xếp hạng này tạo thành cơ sở để lựa chọn bản quét nào và các cuộc tấn công sẽ được chọn để thực hiện tiếp theo. Cấp độ cao Việc thực hiện giai đoạn phân tích được thể hiện trong Giai đoạn thích ứng 2: Phân tích. Trách nhiệm chính của phân tích là thu thập và cập nhật các yếu tố bộ nhớ của chiến lược kiểm tra thâm nhập và gọi hàm cập nhật bộ nhớ (dòng 2) mà lần lượt tạo ra thông tin cần thiết cho thành phần lập kế hoạch để lựa chọn tiếp theo quét và tấn công sẽ được thực hiện.

Giai đoạn thích ứng 2: Phân tích

```
1 Chức năng phân tích_chạy( )
      Đầu vào: Cơ sở kiến thức = , , ,
2         = ( ) ,
3     planning_run( )
4 kết thúc
```

Lập kế hoạch. Giai đoạn lập kế hoạch có hai mục tiêu chính, đó là lựa chọn mục tiêu các thành phần của chu kỳ thích ứng hiện tại và để lựa chọn các cuộc tấn công và quét sẽ được thực hiện dựa trên chúng. Giai đoạn lập kế hoạch sẽ bao gồm tính đến mục tiêu và thứ hạng tấn công được tính toán trong giai đoạn trước, trạng thái ước tính hiện tại của hệ thống mục tiêu và tính khả dụng của các tài nguyên của hệ thống được quản lý và quyết định các mục tiêu tiếp theo cho các cuộc tấn công và quét, ngoài các thông số của chúng. Giai đoạn lập kế hoạch hoạt động cấp cao được thể hiện trong Giai đoạn thích ứng 3: Lập kế hoạch. Trong kết nối với vấn đề được trình bày trong Phần 4, lập kế hoạch lựa chọn các cuộc tấn công và quét tiếp theo sẽ được thực hiện, tức là các hành động kiểm tra xâm nhập trong bằng cách áp dụng hành động di chuyển tiếp theo (dòng 2).

Giai đoạn thích ứng 3: Lập kế hoạch

```
1 Hàm planning_run( )
      Đầu vào: Cơ sở kiến thức = , , ,
      // Nhận các cuộc tấn công và quét mới theo =
2         , , )
3     ( execution_run( , , )
4 kết thúc
```

Thực hiện. Giai đoạn thực hiện cấu hình và kiểm soát các công cụ bao gồm hệ thống được quản lý dựa trên kết quả của kế hoạch giai đoạn. Bản thân các công cụ và cấu hình của chúng có thể được phân loại rộng rãi được phân loại thành hai loại: (i) công cụ khai thác, bao gồm: khung khai thác, công cụ bẻ khóa, công cụ phát hiện tấn công, v.v. và (ii) các công cụ khai thác sau bao gồm các công cụ được sử dụng để khám phá dịch vụ và quy trình, di chuyển ngang, duy trì, chỉ huy và kiểm soát, Exfiltration, v.v. Execution thực hiện các cuộc tấn công trong hoặc quét trong được quyết định bởi giai đoạn lập kế hoạch. Hoạt động cấp cao của giai đoạn thực thi được thể hiện trong Giai đoạn Thích ứng 4: Execution. execution_run cập nhật các bộ quét và tấn công đang hoạt động (dòng 3 và 7) và bắt đầu các cuộc tấn công và quét tương ứng (dòng 4 và 8). execution_control chạy khi một cuộc tấn công đã kết thúc. Nó cập nhật tập hợp các cuộc tấn công đang hoạt động (dòng 12) và tập hợp các cuộc tấn công thành công hoặc thất bại (dòng 14 hoặc 17). Nếu cuộc tấn công thành công, sau đó nó sẽ cập nhật thêm trình kiểm tra xâm nhập khả năng (dòng 15). Nếu mục tiêu kiểm tra thâm nhập đã đạt được, thoát khỏi vòng lặp (dòng 19 và 21, nếu không thì một giai đoạn giám sát mới sẽ bắt đầu (dòng 22).

5.3. Khởi tạo máy chủ và dịch vụ nhắm mục tiêu

Để thúc đẩy tính khả thi của thiết kế chung của chúng tôi trong một thực tế thiết lập, chúng tôi trình bày một ví dụ về kiến trúc chung và các thuật toán bắt buộc (cụ thể cho thiết kế). Phiên bản này nhắm mục tiêu đến các hệ thống với các máy chủ, các dịch vụ được các máy chủ này tiếp xúc (hoặc các quy trình đang chạy trên chúng) và các tương tác qua mạng cục bộ. Để đạt được mục đích đó, một số lượng quyết định được yêu cầu liên quan đến: (i) các công cụ mà được sử dụng bởi hệ thống được quản lý hoặc được triển khai tới các mục tiêu trong quá trình khai thác sau, (ii) phương pháp mô hình hóa tấn công, (iii) phương pháp phân tích lỗ hổng và (iv) mục tiêu và quét và tấn công phương pháp lựa chọn.

Các công cụ thăm dò, khai thác và hậu khai thác. Chúng tôi đã chọn một bộ công cụ đại diện được sử dụng rộng rãi và quen thuộc với việc thâm nhập các công cụ kiểm tra ngoài các tiện ích hệ thống cơ bản có thể được sử dụng như các công cụ đa năng cho nhiều nhiệm vụ quét và khai thác sau. Bảng 15 trong Phụ lục hiển thị danh sách một phần các công cụ tạo nên hệ thống được quản lý được sử dụng để tạo ra các cuộc tấn công của chúng tôi, ngoài các đầu dò và công cụ khai thác sau đó nằm trong phạm vi được quản lý hệ thống hoặc được triển khai trên các máy chủ mục tiêu bị khai thác.

Mô hình tấn công. Thay vì một mô hình tấn công rõ ràng, ví dụ, một cuộc tấn công đồ thị hoặc cây tấn công, chúng tôi sử dụng kiến trúc được thông báo về bảo mật của hệ thống mục tiêu như một mô hình tấn công ngầm. Chúng tôi duy trì một mô hình kiến trúc của các thành phần đã biết của hệ thống mục tiêu, giao diện của chúng và sự tương tác của chúng, cùng với một số biện pháp bảo mật có liên quan các thuộc tính, tức là kiến trúc được thông báo về bảo mật của hệ thống mục tiêu,

Machine Translated by Google

Giai đoạn thích ứng 4: Thực hiện

```
1  Hàm execution_run( , )  ,
       Đầu vào: Tập hợp các cuộc tấn công mới sẽ được bắt đầu
       Đầu vào: Tập hợp các lần quét mới sẽ được bắt đầu
       Đầu vào: Cơ sở kiến thức = , , ,
       // Thêm đòn tấn công vào đòn tấn công đang hoạt động và bắt đầu nó
2      đối với LÀM
3          = { }
4          tấn công_bắt đầu( )
5  kết thúc
       // Thêm quét vào các lần quét đang hoạt động và bắt đầu quét
6      cho làm
7          = { }
8          quét_bắt đầu( )
9  kết thúc
10 kết thúc
11 Hàm execution_control( , )
       Đầu vào: Một cuộc tấn công đã hoàn thành
       Đầu vào: Cơ sở kiến thức = , , ,
       // Cập nhật các cuộc tấn công đang hoạt động
12     = { }
13     nếu thành công( ) thì
           // Cập nhật các cuộc tấn công thành công
14             = { }
           // Cập nhật trạng thái kiểm tra thâm nhập với các khả năng mới
15             = +
16     khác
           // Cập nhật các cuộc tấn công thất bại
17             = { }
18 kết thúc
       // Không có cuộc tấn công hoặc quét nào đang hoạt động hoặc còn lại để thử
19     nếu ( ) = ( ) = thì
           // Pentest hoàn tất
20         write_report_and_exit()
21     khác
           // Bắt đầu một vòng lặp thích ứng mới
22         monitor_run( , )
23 kết thúc
24 kết thúc
```

để theo dõi trạng thái kiểm tra xâm nhập và hỗ trợ lỗ hổng phân tích. Kiến trúc được thông báo về bảo mật được lưu giữ trong kiến thức cơ sở và được cập nhật liên tục khi chạy. Sử dụng một Kiến trúc như một mô hình tấn công ngầm có những ưu điểm sau: nó thể hiện một cách cô đọng trạng thái thử nghiệm thâm nhập và cho phép động, cập nhật thông tin cần thiết cho quyết định tiện ích khi chạy thời gian thực làm cho hoạt động mà không cần phải xây dựng và duy trì đồ họa mô hình tấn công có thể tốn kém để tạo và cập nhật động khi chạy.

Để mô tả các cuộc tấn công có thể xảy ra, chúng tôi phát triển một danh mục tấn công, mà chúng tôi cũng lưu trữ trong cơ sở kiến thức, từ đó các cuộc tấn công có thể được thực hiện được chọn, khởi tạo và thử nghiệm trên máy chủ và dịch vụ mục tiêu. Các đòn tấn công bao gồm một số chiến thuật tấn công. Một cuộc tấn công chiến thuật kết hợp nhiều kỹ thuật tấn công với một mục tiêu chung. Mỗi lần thực hiện kỹ thuật là một bước tấn công. Ví dụ, một cuộc tấn công chiến thuật với mục tiêu đạt được quyền truy cập vào hệ thống quản lý hành chính giao diện của máy chủ web có thể bao gồm các bước tấn công sau: (i) sử dụng skipfish để liệt kê các URL có thể truy cập được, theo sau là (ii) một Tập lệnh khám phá NSE để xác định biểu mẫu truy cập của quản trị viên và như một bước cuối cùng (iii) sử dụng hydra để tấn công dữ dội vào biểu mẫu và giành quyền truy cập.

Kiến trúc của chúng tôi tự động hóa các khía cạnh phối hợp, ra quyết định thời gian chạy, đồng bộ hóa và vận hành công cụ của thử nghiệm thâm nhập dựa trên khả năng khai thác được cung cấp bởi các kỹ thuật tấn công tạo nên các chiến thuật của kho vũ khí tấn công và khả năng phát hiện được cung cấp bởi các lần quét tạo nên kho vũ khí quét. Đổi lại, hiệu quả của các kỹ thuật tấn công và quét phụ thuộc vào khả năng sẵn có của việc khai thác cơ bản, sau khai thác và các công cụ quét. Do đó, kiến trúc sẽ không thể thực hiện bất kỳ cuộc tấn công nào vào máy chủ có dịch vụ hoặc quy trình không thể phát hiện được bởi các lần quét trong danh mục quét hoặc không có trong một bước của chiến thuật tấn công. Có nghĩa là, chúng tôi tự động hóa việc lựa chọn và ứng dụng của các cuộc tấn công đã biết trước đó, chung chung và có thể áp dụng rộng rãi hơn là phát minh ra các kỹ thuật tấn công mới.

Phân tích lỗ hổng. Để thực hiện phân tích lỗ hổng, chúng tôi sử dụng quyết định dựa trên tiện ích để xác định mức độ dễ bị tổn thương của từng máy chủ là và những lần quét và tấn công nào sẽ hiệu quả nhất đối với từng loại máy chủ. Kết quả của quá trình này là xếp hạng các mục tiêu, quét và Các cuộc tấn công dựa trên tính hữu ích của chúng. Chúng tôi đã chọn sử dụng phương pháp ra quyết định dựa trên tính hữu ích để xếp hạng các mục tiêu, quét và tấn công vì nó đã thường được sử dụng trong các hệ thống tự thích ứng để chế ngự môi trường sự không chắc chắn (Glazier và cộng sự, 2017). Hơn nữa, nó cũng đi kèm với lợi thế của việc có độ phức tạp tính toán rất thấp, có thể cung cấp khả năng ra quyết định trong thời gian chạy và không yêu cầu đào tạo, làm cho nó trở thành ứng cử viên phù hợp cho thử nghiệm thâm nhập hộp đen trong môi trường thực tế. Bảng 6 hiển thị các thuộc tính được lưu trữ trong cuộc tấn công mô hình được coi là các yếu tố để quyết định thứ hạng mục tiêu, trong khi Bảng 7 cho thấy các thuộc tính được xem xét để quyết định cuộc tấn công xếp hạng và Bảng 8 hiển thị các thuộc tính được xem xét để quyết định quá trình quét xếp hạng. Để ngắn gọn, chúng tôi chỉ hiển thị các yếu tố và tương ứng trọng số. Chi tiết đầy đủ, bao gồm các hàm giá trị, đều có sẵn trong Bảng 12, 13 và 14 trong Phụ lục. Do đó, giai đoạn phân tích, thực hiện tính toán tiện ích và xếp hạng theo Công thức (1), được cung cấp cái đó = , , , , , , , , trong đó:

- , Và tương ứng với các vectơ bao bọc các mục nhập trọng số trong Bảng 6, 7 và 8,
- , và tương ứng với các vectơ bao hàm giá trị các mục trong Bảng 12, 13 và 14,
- , và là các vectơ tiện ích, một cho mỗi mục tiêu, tấn công và quét tạo nên thứ hạng được trả về bởi phân tích.

Đối với mọi mục tiêu có sẵn, tấn công và quét (dòng 2, 6 và 10), chúng tôi tính toán tiện ích của nó theo Công thức (1) (dòng 3, 7 và 11). Khi tiện ích của mọi tùy chọn, tức là, tấn công, quét hoặc mục tiêu đã được tính toán, chúng tôi xếp hạng chúng bằng cách sắp xếp mảng tương ứng (dòng 5, 9 và 13) và lọc ra những mục không có giá trị sử dụng.

Cập nhật bộ nhớ: ADAPT

```
1  Hàm ( , )
       Đầu vào: Các phần tử bộ nhớ,
                = , , , , , , , ,
       Đầu vào: Trạng thái kiểm tra thâm
2      nhập cho ( ) làm
3          ( ) = ( )
                ,
4  kết thúc
5      loại( )
6      đối với ( ) thì
7          ( ) = ( )
                .
8  kết thúc
9      sắp xếp( )
10     đối với ) LÀM
11         ( ( ) = ( )
                ,
12 kết thúc
13     loại( )
14 kết thúc
```

Lập kế hoạch. Quá trình lập kế hoạch được hướng dẫn bởi kết quả của mục tiêu và xếp hạng tấn công, có tính đến hai yếu tố bổ sung: (i) một ngưỡng cho mỗi số lượng mục tiêu đồng thời ( ) và các cuộc tấn công ( ) và (ii) các cuộc tấn công và công cụ khai thác sau đó đã hoạt động.

Machine Translated by Google

Bảng 6
Các yếu tố quyết định mục tiêu.

Nhân tố	Cân nặng
Số lượng dịch vụ (S)	0,2
Số lượng lỗ hổng (V)	0,2
Số lượng kết nối (C)	0,2
Nhà nước khai thác (E)	0,4

Bảng 7
Các yếu tố quyết định tấn công.

Nhân tố	Cân nặng
Vectơ tấn công (V)	0,3
Độ phức tạp của cuộc tấn công (C)	0,2
Quyền bắt buộc (P)	0,2
Tương tác người dùng (U)	0,1
Thời gian chạy (T)	0,2

Bảng 8
Quét các yếu tố quyết định.

Nhân tố	Cân nặng
Phạm vi quét (R)	0,25
Số lượng mục tiêu (T)	0,25
Thời lượng quét (D)	0,25
Độ phức tạp quét (C)	0,25

Chúng tôi sử dụng thuật toán phân bổ tài nguyên cơ bản như được hiển thị trong Tiếp theo Di chuyển: THÍCH NGHI để chọn các hành động tiếp theo sẽ được thực hiện trong giai đoạn thực hiện, tức là, gọi . Mô tả cấp cao của thuật toán phân bổ mục tiêu, target_selection, như sau: miễn là số lượng mục tiêu đồng thời được phép ( ) không bị vượt quá (dòng 10), chúng ta duyệt qua thứ hạng của các mục tiêu và thêm mục tiếp theo mục tiêu có giá trị nhất (dòng 14), với điều kiện là: (i) nó chưa được hoàn toàn đã được khai thác và (ii) chưa có trong danh sách các mục tiêu đang hoạt động (dòng 13). Tương tự như vậy, thuật toán phân bổ tấn công attack_selection sẽ phân bổ một cuộc tấn công (dòng 28), nếu số lượng các cuộc tấn công đồng thời được phép ( ) chưa được vượt quá (dòng 25), với điều kiện là: (i) nó tấn công một hoạt động mục tiêu, (ii) chưa từng được thử trước đây, (iii) không có trong danh sách các cuộc tấn công chủ động vào mục tiêu và (iv) nó không can thiệp vào các mục tiêu khác các cuộc tấn công đang diễn ra (dòng 27). Vì lợi ích của sự ngắn gọn, chúng tôi không đưa ra hàm scan_selection, vì nó gần giống với hàm attack_selection

Bước tiếp theo: THÍCH NGHI

```
 1 Hàm ( , )
       Đầu vào: Các phần tử bộ nhớ,
                  =      ,   ,    ,   ,   , ,    ,   ,
       Đầu vào: Trạng thái kiểm tra thâm
 2         nhập = target_selection()
 3         = lựa chọn tấn công(   )
 4         = quét_lựa_chọn( )
 5     trở lại     ,
 6 kết thúc
 7 Hàm target_selection()
       Đầu vào: xếp hạng tiện ích mục tiêu,
 8         =
 9         = -       |   |
10         = 0
11     trong khi      > 0    < | | làm
12         = mục tiêu_từ_idx( , )
13         nếu    ( ) thì
14             =         { }
15             = - 1
16         kết thúc
17         = + 1
18 kết thúc
19     trở lại
20 kết thúc
21 Chức năng attack_selection(   )
       Đầu vào: xếp hạng tiện ích mục tiêu,
22         =
23         = - |    |
24         = 0
25     trong khi > 0    < |   | làm
26         = tấn công từ idx(     ,    )
27         nếu   (                  )   ¬can thiệp( ,     )   mục tiêu của( )
           sau đó
28             =    { }
29             = - 1
30         kết thúc
31         = + 1
32 kết thúc
33     trở lại
34 kết thúc
```

Ví dụ 1. Để minh họa cách phân tích lỗ hổng và mục tiêu và công việc phân bổ tấn công, chúng tôi chứng minh hai mục tiêu chu kỳ thích ứng và các quyết định tấn công cho hệ thống được hiển thị trong Hình 1. Nói cách khác, chúng ta sẽ đi qua các phần Cập nhật bộ nhớ và Di chuyển tiếp theo của THÍCH NGHI với mục tiêu và ngưỡng tấn công được đặt thành 1. Để ngắn gọn, chúng tôi bỏ qua việc thảo luận về các quyết định quét vì chúng tương tự như quyết định tấn công. Chúng tôi coi trạng thái thử nghiệm thâm nhập ban đầu là trạng thái sau khi quét mạng đã chạy, nơi chỉ có hai internet các thành phần đối mặt và hai giao diện đối mặt với internet đã được đã được xác định. Trạng thái thử nghiệm thâm nhập hiện tại bao gồm: = { } và = { }. Bảng 9 cho thấy , các giá trị đầu vào nhân tố ngoài tổng tiện ích tương ứng cho mỗi mục tiêu hợp lệ và tấn công sau khi chạy. tính toán tiện ích theo Phương trình (1) và đưa các giá trị đầu vào của hệ số vào giá trị các chức năng được đưa ra trong Bảng 12 và 13 của Phụ lục. Cả hai thành phần có cùng số lượng dịch vụ, lỗ hổng và hiện đã biết các kết nối và đang ở cùng một trạng thái khai thác, do đó tiện ích của nhắm mục tiêu được tính là: 0,332. Hơn nữa, chúng ta hãy giả sử rằng danh mục tấn công chỉ bao gồm hai chiến thuật tấn công có thể xảy ra: (i) HTTP Form Cracking nhắm mục tiêu vào WebServer và (ii) một khai thác tùy chỉnh tận dụng lỗ hổng ghi ngoài giới hạn trong triển khai Triển khai gRPC trên APIGate. Cả hai cuộc tấn công đều có thể được thực hiện trên mạng và không yêu cầu bất kỳ đặc quyền hoặc tương tác nào của người dùng. Tuy nhiên, HTTP Form Cracking có độ phức tạp tấn công thấp và thời gian tấn công dài. thời gian chạy, trong khi khai thác tùy chỉnh có độ phức tạp tấn công cao và thời gian chạy nhanh. Do đó, tiện ích của việc sử dụng Biểu mẫu HTTP Bẻ khóa là: 0,863 và tiện ích của việc sử dụng khai thác tùy chỉnh là: 0,903. Vì tiện ích của WebServer và APIGate là giống nhau target_selection sẽ chọn mục đầu tiên được tìm thấy trong bảng đã sắp xếp, trong trường hợp này, WebServer là mục tiêu được khai thác, di chuyển nó đến tập hợp mục tiêu đang hoạt động. Hàm attack_selection sau đó sẽ chạy và sẽ chọn cuộc tấn công bẻ khóa biểu mẫu HTTP vì đó là cuộc tấn công duy nhất có thể nhắm vào mục tiêu đang hoạt động.

Khi việc bẻ khóa biểu mẫu HTTP thành công, nó sẽ cấp quyền truy cập hạn chế cho người dùng đến thành phần WebServer, cho phép quét quy trình, trong đó lần lượt tiết lộ một tệp nhị phân sudo dễ bị tấn công. Hơn nữa, việc quét mở các cổng trên WebServer đã tiết lộ rằng một thành phần mới, Cơ sở dữ liệu là có thể truy cập thông qua WebServer. Vì không có quét cổng nào được chạy trên Cơ sở dữ liệu, không có giao diện nào được biết đến. Trạng thái kiểm tra thâm nhập là do đó được cập nhật tương ứng để bao gồm một giao diện bổ sung cho quá trình sudo được phát hiện và một thành phần bổ sung, tức là, = Hơn nữa, các giá trị liên quan của các yếu tố = WebServer được cập nhật tương ứng. Bảng 10 hiển thị các giá trị yếu tố được cập nhật tương ứng với tiện ích.

cho bước thích ứng tiếp theo. Trong trạng thái kiểm tra thâm nhập mới, một cuộc tấn công mới việc nhắm mục tiêu vào tệp nhị phân sudo dễ bị tấn công là khả thi, trong khi biểu mẫu HTTP cuộc tấn công nứt đã thành công không còn khả thi nữa. Sau chạy, như kết quả cho thấy trong Bảng 10, mục tiêu có nhiều nhất Tiện ích là WebServer với tiện ích là 0,456. Vì chúng ta xem xét mục tiêu

Machine Translated by Google

Bảng 9
Tiện ích trạng thái kiểm tra thâm nhập trước chu kỳ thích ứng đầu tiên.

Tiện ích mục tiêu					
Mục tiêu (Máy chủ)	S	TRONG	C	VÀ	Tính thiết thực
Máy chủ web	1	0	1	Không có	0,332
Cổng API	1	0	1	Không có	0,332

Tiện ích tấn công						
Tấn công	TRONG	C	P	TRONG	T	Tính thiết thực
gRPCBOF	Mạng lưới	Cao	Không có	Không có	Nhanh	0,903
HTTPCrack	Mạng lưới	Thấp	Không có	Không có	Dài	0,863

Bảng 10
Tiện ích trạng thái Pentest sau chu kỳ thích ứng đầu tiên.

Tiện ích mục tiêu					
Mục tiêu (Máy chủ)	S	TRONG	C	VÀ	Tính thiết thực
Máy chủ web	1	1	2	Không có	0,456
Cổng API	1	0	1	Không có	0,332
Cơ sở dữ liệu	0	0	1	Không có	0,312

Tiện ích tấn công						
Tấn công	TRONG	C	P	TRONG	T	Tính thiết thực
gRPCBOF	Mạng lưới	Cao	Không có	Không có	Nhanh	0,903
SudoPWN	Địa điểm	Cao	Thấp	Không có	Nhanh	0,752

ngưỡng 1, mục tiêu được chọn sau khi chạy target_selection sẽ là WebServer và thuật toán attack_selection sẽ một lần nữa chọn lựa chọn khả thi duy nhất để tấn công WebServer, mục tiêu hoạt động duy nhất, tức là SudoPWN.

5.4. Chi tiết triển khai

Kiến trúc cụ thể của ADAPT được thể hiện trong Hình 4. Hệ thống quản lý được triển khai bằng cách khởi tạo một vòng lặp MAPE-K đa luồng điều khiển sự kiện, vòng lặp này triển khai các thuật toán mô hình hóa tấn công, phân tích lỗ hổng và lập kế hoạch được mô tả trong Phần 5.3 .
hệ thống được quản lý được triển khai như một tập hợp các bước quét và tấn công các plugin thực thi được quản lý bởi giám sát và thực thi các thành phần tương ứng. Chúng tôi đã thiết kế hệ thống được quản lý với một kiến trúc dựa trên plugin, để các plugin công cụ khác nhau có thể cung cấp khả năng hỗ trợ nhiều kỹ thuật tấn công.

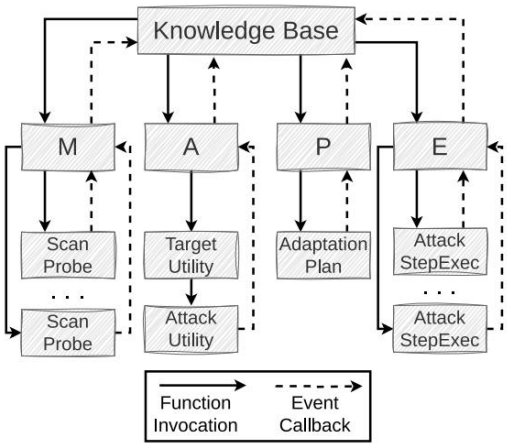
Các plugin được cấp quyền truy cập vào mô hình kiến trúc của mục tiêu hệ thống và sử dụng các đặc tính kiến trúc của các thành phần hoặc giao diện của nó để thiết lập và kiểm tra các khả năng cần thiết để thực hiện các hành động liên quan đến bước quét hoặc tấn công. Ví dụ, một bước tấn công yêu cầu thông tin đăng nhập của người dùng không có đặc quyền như một điều kiện tiên quyết để khai thác một lỗ hổng leo thang đặc quyền cục bộ trên một thành phần có thể truy vấn các thuộc tính của thành phần để tìm và sử dụng các thông tin xác thực đó. Plugin tuân theo một API đơn giản, đối với mỗi hành động (bước quét hoặc tấn công) mà họ cung cấp, hai chức năng được triển khai: một chức năng bảo vệ kiểm tra cho dù các khả năng cần thiết để thực hiện bước tấn công hoặc quét đã được mua lại và một hàm chạy thực thi lõi của plugin chức năng.

Mã nguồn công cụ được phát hành theo giấy phép mở.6 Do cân nhắc về mặt đạo đức, chúng tôi không phát hành công khai các plugin công cụ xâm nhập , nhưng chúng tôi cam kết mở khoa học và sẽ tạo điều kiện cho thí nghiệm sao chép và so sánh.

6. Đánh giá

Chúng tôi đã triển khai kiến trúc được mô tả trong Phần 5.4, mà chúng tôi sẽ đánh giá trong phần này. Chúng tôi sẽ so sánh công cụ của mình với Metas-ploitable2, Metasploitable3 và mạng dựa trên máy ảo (VM). Metasploitable2

6 https://gitfront.io/r/anonymous-submitter/P2LRhxvh9L7z/ADAPT/.



Hình 4. Kiến trúc bê tông của ADAPT.

và Metasploitable3 là các máy ảo dễ bị tấn công thường được sử dụng làm mục tiêu đầu tiên để kiểm tra các công cụ kiểm tra thâm nhập. Mạng dựa trên VM đã được được phát triển tại Đại học Linköping để phục vụ như một phần phòng thí nghiệm của một khóa học trong việc hack có đạo đức. Mục tiêu của các thí nghiệm là để chứng minh rằng ADAPT có thể thực hiện thử nghiệm thâm nhập vào một hệ thống thực tế tự chủ, đưa ra tất cả các quyết định có liên quan để thỏa hiệp hệ thống trong một số hành động hợp lý, với chi phí tối thiểu, và không được truy cập vào bất kỳ thông tin cụ thể nào về kiến trúc hoặc chức năng của hệ thống ngoài thông tin được sử dụng để xây dựng bản quét và các đòn tấn công.

6.1. Thiết lập thí nghiệm

Metasploitable2 là một máy ảo (VM) cố tình dễ bị tấn công chạy Ubuntu 8.04. Nó phơi bày nhiều dịch vụ dễ bị tấn công bao gồm nhiều dịch vụ không được bảo vệ bằng mật khẩu (smtp, rlogin, rsh, rexec, nfs), nhiều cửa hậu (vsftpd, unrealIRCd), các dịch vụ có mật khẩu yếu (ssh, telnet, postgres, vnc) và các dịch vụ có lỗ hổng bảo mật đã biết (httpd, javarmi, samba). Hơn nữa, vì phiên bản hạt nhân đã lỗi thời nên có nhiều cách khai thác leo thang đặc quyền sau khi người dùng cục bộ đã có được quyền truy cập. Tương tự, Metaspoitable3 đã được thiết kế và có sẵn cho cùng mục đích mặc dù có mức độ cao hơn của độ khó. Nó có hai phiên bản, như Windows windows2008 hoặc như một máy chủ Ubuntu 14.04. Chúng tôi đã chọn sử dụng phiên bản Windows trong đánh giá của chúng tôi. Nhiều dịch vụ dễ bị tổn thương hoặc các dịch vụ có mật khẩu yếu cũng bị Metasploitable3 phát hiện, bao gồm cả Ví dụ, struts, glassfish, mysql, iis-ftp, iis-http, v.v.

Thiết lập mạng VM bao gồm cả Windows Server 2k19 và Máy ảo Ubuntu 18.04, được kết nối trong một mạng ảo. Thiết lập mạng VM được sử dụng trong khóa học hack đạo đức ở cấp độ thạc sĩ dành cho sinh viên khoa học máy tính. Khóa học tương ứng với 4 tuần các nghiên cứu toàn thời gian và phần phòng thí nghiệm của nó tương ứng với 3 tuần nghiên cứu toàn thời gian được chia thành 16 tuần theo lịch. Mười một lá cờ được nhúng trong hệ thống máy chủ. Việc giành được các cờ, đòi hỏi phải sử dụng nhiều các công cụ khai thác khác nhau, ngoài việc khám phá mạng và quy trình, leo thang đặc quyền, đánh hơi mạng và di chuyển ngang thông qua mạng lưới. Để đưa ra một cảm nhận sơ bộ về mức độ khó khăn của phòng thí nghiệm, có thể đóng vai trò ước tính nỗ lực cần thiết để thực hiện kiểm tra thâm nhập thủ công so với thiết lập phòng thí nghiệm của chúng tôi, chúng tôi cung cấp số liệu thống kê thời gian dành cho việc chiếm giữ các lá cờ khác nhau trong mùa xuân năm 2024. học sinh được chia thành 39 nhóm, mỗi nhóm hai người. Hình 5 cho thấy hoạt động cướp cờ thống kê theo tuần.

Machine Translated by Google

	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
F_1	9	29	36	36	36	36	36	36	36	36	36	36	36	36	36	36
F_2	7	16	31	36	36	36	36	36	36	36	36	36	36	36	36	36
F_3	4	17	25	31	35	38	38	38	38	38	38	38	38	38	38	38
F_4	3	9	15	25	34	34	34	34	34	35	35	36	36	36	36	36
F_5	1	7	11	19	25	29	30	31	31	31	32	33	33	33	33	33
F_6	0	0	0	0	0	0	1	7	12	29	30	30	31	31	34	34
F_7	0	0	0	0	0	0	0	0	0	12	23	28	28	29	30	31
F_8	0	0	0	0	0	0	0	1	1	12	19	27	27	28	30	30
F_9	0	0	0	0	0	0	0	0	0	2	9	20	26	27	29	31
F_{10}	0	0	0	0	0	0	0	0	0	1	10	20	26	26	27	30
F_{11}	0	0	0	0	0	0	0	0	0	0	0	3	4	4	7	18

Hình 5. Các nhóm đã chiếm được mỗi lá cờ trong mỗi tuần.

6.2. Thiết lập công cụ ban đầu

Chúng tôi giả định một thiết lập kiểm tra xâm nhập hộp đen; chỉ có quyền truy cập vào phạm vi mạng nơi các máy chủ lưu trú và mã định danh cờ được cung cấp cho công cụ. Bất kỳ máy chủ nào trong phạm vi đều có thể bị nhắm mục tiêu bởi các máy quét, công cụ tấn công hoặc công cụ kiểm tra xâm nhập, và một khi có được quyền truy cập đặc quyền, có thể bị sửa đổi để phục vụ nhu cầu của kẻ tấn công, ví dụ: để thực hiện các cuộc tấn công tiếp theo vào các mục tiêu hợp lệ khác trong phạm vi. Không có thông tin nào được cung cấp về các dịch vụ có thể có trên bất kỳ máy chủ nào hoặc bất kỳ lỗ hổng tiềm ẩn nào.

ADAPT triển khai kiến trúc được trình bày trong Phần 5.4, do đó, nó sử dụng các chức năng được mô tả trong Next Move(s) ADAPT để lựa chọn mục tiêu và tấn công. ADAPT được trang bị một kho quét có khả năng thực hiện 8 lần quét và một kho tấn công với 41 chiến thuật tấn công và 57 kỹ thuật tấn công. Khả năng quét và khai thác được cung cấp bởi các kho này ảnh hưởng trực tiếp đến mức độ thành công của bài kiểm tra thâm nhập. Do đó, để thể hiện chức năng của ADAPT, chúng tôi đã chọn sử dụng các kho chứa các khả năng cần thiết để hoàn thành thành công các cuộc khai thác riêng lẻ đối với các máy chủ của mạng VM. Chúng tôi không đánh giá thành công của ADAPT dựa trên việc có đủ kho quét và tấn công để phát hiện và khai thác mọi lỗ hổng trên mỗi máy chủ một cách độc lập, mà dựa trên khả năng (i) điều hướng thành công mạng VM, (ii) đưa ra các quyết định thời gian chạy cần thiết để thúc đẩy trạng thái kiểm tra thâm nhập và (iii) vận hành các công cụ quét, khai thác và hậu khai thác với tham số hóa phụ thuộc vào ngữ cảnh phù hợp. Việc thiết lập các danh mục tấn công và quét bao gồm việc thiết kế các chiến thuật tấn công và lựa chọn các lần quét cần thực hiện. Thiết kế chiến thuật tấn công bao gồm việc lựa chọn các kỹ thuật tấn công sẽ sử dụng, trình tự thực hiện và các giá trị tiện ích tương ứng cho từng yếu tố.

6.3. Kết quả

Bảng 11 tóm tắt kết quả kiểm tra xâm nhập theo từng trường hợp nghiên cứu. Cụ thể, chúng tôi hiển thị số lượng máy chủ có thể khai thác và bị khai thác, số lượng dịch vụ có thể khai thác và bị khai thác và chuỗi tấn công lớn nhất. Đối với Metasploitable2 và Metasploitable3, số lượng tổng số máy chủ và số lượng máy chủ có thể khai thác trùng khớp, tuy nhiên, đối với trường hợp nghiên cứu mạng VM, tồn tại thêm 2 máy chủ mồi không có bất kỳ điểm yếu nào có thể khai thác. Hơn nữa, vì mục tiêu của thử nghiệm VM là nhanh chóng tìm ra tất cả các cờ và chiếm quyền kiểm soát hệ thống, ADAPT không khai thác tất cả các dịch vụ có thể khai thác mà thay vào đó cố gắng tìm ra các cờ trong càng ít bước càng tốt. Nói cách khác, nó ưu tiên giành quyền root trên một máy chủ mồi thay vì khai thác một tiến trình/dịch vụ trên máy chủ mà nó đã có quyền root.

Tổng quan về thử nghiệm thâm nhập. Để chứng minh việc thực hiện ADAPT, chúng tôi Hiển thị biểu đồ khai thác, với ngữ nghĩa tương tự như biểu đồ tấn công logic (Ou và cộng sự, 2006). Chúng có các loại nút sau: (i) nút hình elip biểu diễn các kỹ thuật quét (có tiền tố 'S'), khai thác (có tiền tố 'E') và hậu khai thác (có tiền tố 'P'), (ii) nút hình chữ nhật biểu diễn các giao diện (dịch vụ hoặc quy trình) và (iii) nút hình thoi biểu diễn các khả năng đã đạt được. Chúng tôi tô màu đỏ cho mục tiêu cuối cùng của kẻ tấn công, đó là giành được quyền root cho Metasploitable2 và Metasploitable3 và thu thập tất cả các cờ cho mạng VM.

Metasploitable2 và Metasploitable3 Để thực hiện kiểm tra xâm nhập đối với Metasploitable2, ADAPT chỉ cần sử dụng một vài công cụ bao gồm: (i) nmap để quét dịch vụ và lỗ hổng, cũng như để tấn công bruteforce thông tin đăng nhập FTP và biểu mẫu http, và (ii) metasploit để khai thác và bẻ khóa mật khẩu. Hình 6 cho thấy biểu đồ khai thác được tạo ra bằng cách hợp nhất kết quả của nhiều lần thực thi ADAPT.

Mô tả về từng nút trong biểu đồ khai thác và thời gian chạy trung bình cho các hoạt động quét, khai thác và sau khai thác có thể được tìm thấy trong Bảng 17 ở Phụ lục. Việc có được quyền root (hiển thị trong Hình 6) trên Metasploitable2 thường yêu cầu khai thác một lỗ hổng người duy nhất là 6 và có thể đạt được thông qua 11 giao diện khác nhau, 15. Hơn nữa, một dùng thông thường, msfadmin (hiển thị là 4), có đặc quyền sudo không cần mật khẩu, dẫn đến 5 ĐẾN xâm phạm hai bước. Công cụ này cũng đã phát hiện ra một đường dẫn khai thác dài hơn bằng cách truy cập thông qua dịch vụ httpd dễ bị tấn công (). Lỗ hổng CGI Argument cho phép truy cập thiết bị đầu cuối cho người dùng www-data (sau đó chạy một loạt các trình quét leo thang đặc quyền, 1 , 2 và trong số đó lần lượt phát hiện ra một loạt các lỗ hổng leo thang đặc quyền được hiển thị là 1 , 2 và mỗi lỗ hổng trong số đó có thể 4 5). Các công bị khai thác để leo thang đặc quyền. 3 , cụ mỗi

3 ,

Kết quả chạy công cụ của chúng tôi trên Metasploitable3 có thể được xem trong Hình 7 và Bảng 18 trong Phụ lục. Tương tự như Metasploitable2, biểu đồ khai thác cho thấy nhiều lần chạy công cụ của chúng tôi sử dụng nmap và metasploit. Metasploitable3 đặt ra một thách thức khó khăn hơn để xâm nhập hoàn toàn so với phiên bản tiền nhiệm, thông thường, cần sử dụng ít nhất hai kỹ thuật tấn công để chiếm được quyền root. Kịch bản khai thác phổ biến nhất là phải bẻ khóa mật khẩu của một dịch vụ cho phép truy cập với tư cách người dùng có đặc quyền thấp và thực hiện một cuộc tấn công cho phép công cụ chiếm quyền Hệ thống hoặc Quản trị viên.

Thông thường, điều này được thực hiện bằng cách khai thác lỗ hổng Eternal Blue được xác định 30 bằng cách chạy quét sau khai thác 1. Tuy nhiên, hai dịch vụ, Apache Struts và ManageEngine, cho phép truy cập trực tiếp với đặc quyền cao sau khi bị xâm nhập. Một cách khai thác thú vị không dẫn đến việc đạt được đặc quyền quản trị viên nhưng có hậu quả về bảo mật được công cụ của chúng tôi xác định là khai thác máy chủ web iis-http để đổ bộ nhớ quy trình. Đây là một quy trình gồm hai bước, đầu tiên, một trình bẻ khóa mật khẩu (17) được sử dụng để truy cập vào trình quản lý máy chủ web, sau đó CVE2015-1635 được khai thác thông qua metasploit.

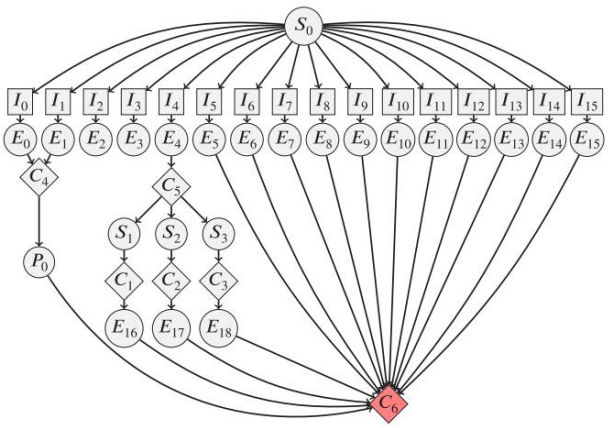
Mạng VM Biểu đồ khai thác cho một lần chạy công cụ của chúng tôi trên thiết lập mạng VM được hiển thị trong Hình 8. Phòng thí nghiệm liên quan đến nhiều máy chủ mạng, chúng tôi sử dụng ký hiệu sau cho các giao diện: '', trong đó và lần lượt biểu thị máy chủ và giao diện và và '' là các số tự nhiên. Chúng tôi hiển thị các cờ được tìm thấy dưới dạng khả năng, được xác định bằng ký tự 'F' ban đầu. Vì các cờ trong mạng VM đang được sử dụng làm tài liệu thi trong nhiều khóa học do các cơ sở giáo dục đại học cung cấp, chúng tôi không thể trình bày hoặc mô tả chi tiết các bước khai thác. Tuy nhiên, chúng tôi đã chọn thêm kết quả kiểm tra thâm nhập của nó để chứng minh khả năng của công cụ trong các nhiệm vụ không được Metasploitable2 và Metasploitable3 đề cập, cụ thể là: di chuyển ngang, ưu tiên giữa các máy chủ khác nhau và khai thác theo chiều sâu. Trái ngược với Metasploitable2 và Metasploitable3, trong đó chỉ có một máy chủ duy nhất và do đó không thể di chuyển ngang và ưu tiên mục tiêu, có nhiều máy chủ trong thiết lập phòng thí nghiệm và di chuyển ngang là yêu cầu để có được tất cả các cờ. Hơn nữa, đường tấn công dài nhất đối với Metasploitable2 yêu cầu 4 hành động của kẻ tấn công (0 , 4 , 2 , 17), bao gồm việc khai thác 2 giao diện. Tối đa 7 hành động của kẻ tấn công (2 , 0 , 19, 28, 1 , 30),

0 ,

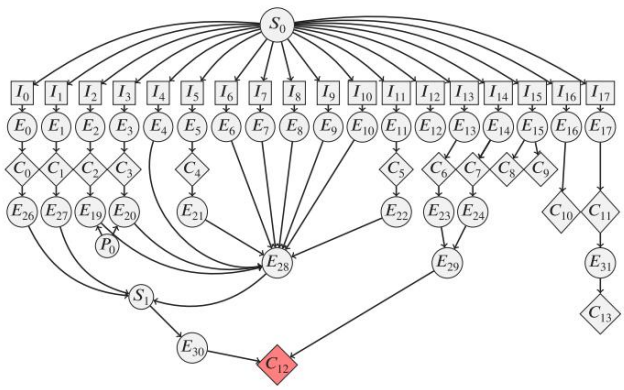
Machine Translated by Google

Bảng 11
Tóm tắt kết quả kiểm tra thâm nhập.

Nghiên cứu điển hình	#Máy chủ có thể khai thác	#Máy chủ đã root	#Dịch vụ có thể khai thác	#Dịch vụ bị khai thác	Chuỗi tấn công dài nhất
Metasploitable2	1	1	16	16	4
Metasploitable3	1	1	18	18	7
Mạng VM	4	4	13	11	12



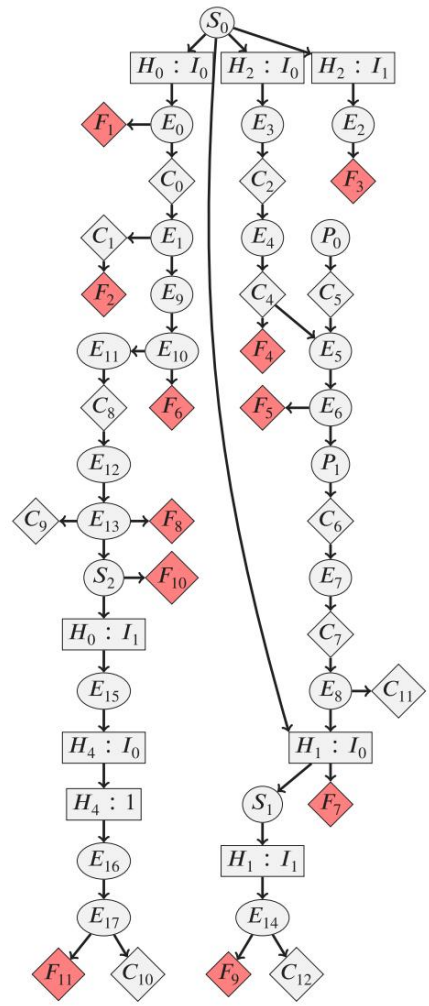
Hình 6. Biểu đồ khai thác cho Metasploitable2, các nút mục tiêu được tô màu đỏ. (Đối với việc giải thích các tham chiếu đến màu sắc trong chú thích hình này, người đọc được giới thiệu đến phiên bản web của bài viết này.)



Hình 7. Biểu đồ khai thác cho Metasploitable3, các nút mục tiêu được tô màu đỏ. (Đối với việc giải thích các tham chiếu đến màu sắc trong chú thích hình này, người đọc được giới thiệu đến phiên bản web của bài viết này.)

được yêu cầu phải xâm phạm Metasploitable3, liên quan đến việc khai thác của 2 giao diện. Độ sâu đường tấn công dài nhất trong mạng VM là 12 hành động (0 9 0 10, 11, 12, 13, 2 , 15, 16, 17) yêu cầu khai thác 4 giao diện( ) trong hai 0 0 , 0 4 0., 4 máy chủ 1 khác nhau. Như được thấy trong biểu đồ khai thác, công cụ của chúng tôi có khả năng tìm thấy tất cả 11 lá cờ; nó cũng có thể có được quyền root trên tất cả máy chủ mạng có thể khai thác.

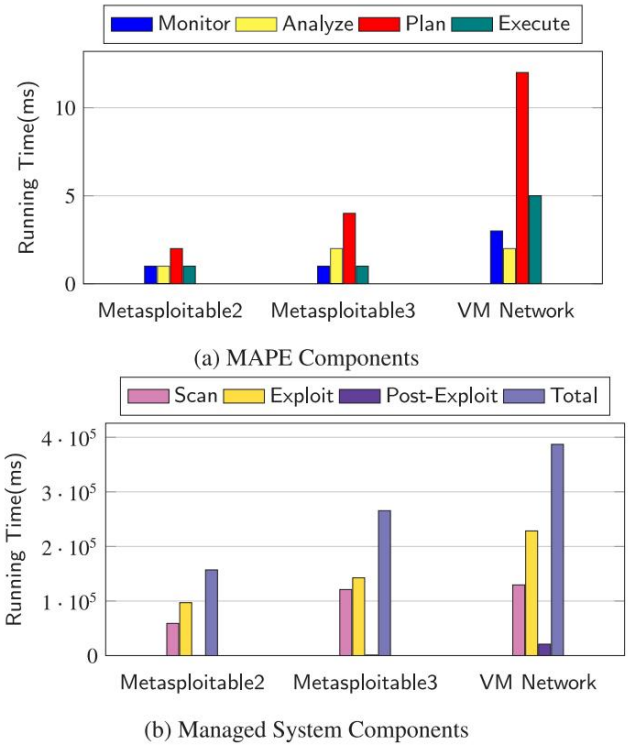
Thống kê ADAPT. Hình 9 hiển thị thời gian chạy của từng thành phần của ADAPT cho mỗi nghiên cứu điển hình của chúng tôi với mục tiêu đồng thời và ngưỡng tấn công được đặt thành 1. Trong cả ba trường hợp, phần lớn thời gian chạy được dành cho các hoạt động của hệ thống được quản lý, tức là trong hoạt động của các công cụ quét, khai thác và hậu khai thác. Trong các thí nghiệm, chỉ cần một vài công cụ khai thác sau: 1 cho Metasploitable2 và Metasploitable3 và 2 cho mạng VM. Trong một nghiên cứu trường hợp khác, có thể cần nhiều hoạt động như vậy hơn. Hoạt động lặp MAPE-K chỉ mất tối đa vài chục mili giây.



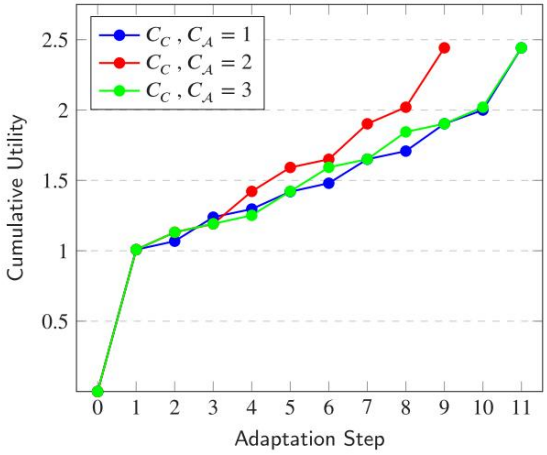
Hình 8. Biểu đồ khai thác môi trường phòng thí nghiệm, các nút mục tiêu được tô màu đỏ. (Để giải thích trong số các tham chiếu đến màu sắc trong chú thích hình này, người đọc được giới thiệu đến phiên bản web của bài viết này.)

Hình 10 cho thấy điểm tiện ích tích lũy sau mỗi lần điều chỉnh bước cho các ngưỡng mục tiêu và tấn công khác nhau trong trường hợp mạng VM nghiên cứu. Như mong đợi, vì các tiết mục giống nhau đang được sử dụng trong tất cả ba lần chạy trên mạng VM, tiện ích hội tụ về cùng một kết quả cuối cùng điểm. Sự khác biệt về tiện ích trên mỗi bước thích ứng có thể được quy cho đến các đường dẫn khác nhau mà công cụ thực hiện tùy thuộc vào số lượng của sự đồng thời được phép. Bước thích ứng tương ứng đang chạy thời gian được đưa ra trong Hình 11, có thể dự đoán được, như ngưỡng đồng thời tăng, tổng thời gian chạy giảm. Tăng ngưỡng từ 1 đến 2, cải thiện đáng kể thời gian chạy, tuy nhiên một ngưỡng tăng từ 2 lên 3 mang lại sự cải thiện tối thiểu. Chúng tôi mong đợi điều này phụ thuộc vào số lượng các đường dẫn khai thác độc lập trong hệ thống mục tiêu. Thật vậy, bằng cách đối chiếu với Hình 8, chúng ta có thể thấy rằng chủ yếu có hai con đường khai thác độc lập hiện diện trong Mạng VM. Một quan sát đáng chú ý là ít bước thích ứng hơn

Machine Translated by Google



Hình 9. Thời gian chạy của mỗi thành phần ADAPT.

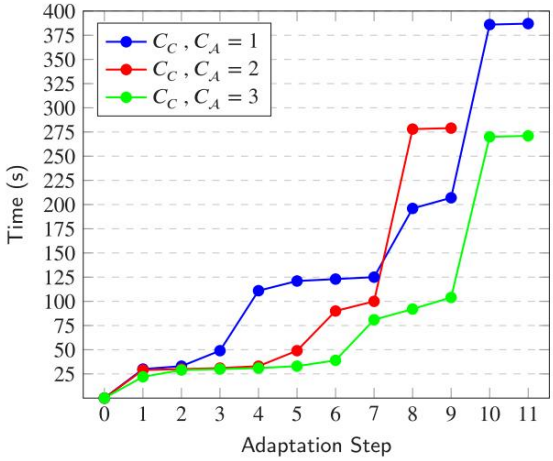


Hình 10. Tiện ích tích lũy của mạng VM.

không nhất thiết ngụ ý tổng thời gian chạy thấp hơn. Thực tế này có thể được quy cho hai yếu tố: (i) hoạt động vòng lặp MAPE-K chiếm một lượng thời gian không đáng kể, và (ii) bản chất dựa trên sự kiện của việc triển khai ADAPT, cho phép kích hoạt các điều chỉnh ngay khi bất kỳ quá trình quét, bước khai thác hoặc chạy công cụ sau khai thác nào hoàn tất.

7. Kết luận

Chúng tôi đã xây dựng quy trình kiểm thử xâm nhập ở cấp độ kiến trúc và đề xuất một kiến trúc tự thích ứng chung để tự động hóa việc kiểm thử xâm nhập. Chúng tôi cũng mô tả chi tiết thiết kế và triển khai ADAPT, một công cụ có thể tự động hóa việc kiểm thử xâm nhập máy chủ.



Hình 11. Thời gian mạng VM cho mỗi bước thích ứng.

và các hệ thống kiểu dịch vụ. Kết quả đánh giá của chúng tôi cho thấy ADAPT có khả năng tự động hóa việc thực hiện các bài kiểm tra thâm nhập trên các hệ thống thực tế. Theo hiểu biết của chúng tôi, ADAPT là công cụ đầu tiên có khả năng tự động hóa tất cả các giai đoạn của quy trình kiểm tra thâm nhập, bao gồm lập kế hoạch, ra quyết định động khi chạy và tự động hóa tấn công, có thể được áp dụng trên các môi trường thực tế.

Trong tương lai, chúng tôi dự định mở rộng tính tự chủ của phương pháp tiếp cận này. Một hướng đi đầy hứa hẹn là kết hợp một phương pháp tạo danh mục tự động, bao gồm khả năng tự động tổng hợp các chiến thuật tấn công từ các kỹ thuật tấn công thành phần. Hơn nữa, chúng tôi dự định nghiên cứu hiệu quả của kiến trúc được đề xuất trong các lĩnh vực khác nhau và như một thành phần của hệ sinh thái công cụ an ninh mạng rộng lớn hơn.

Tuyên bố đóng góp tác giả của CRediT

Charilaos Skandylas: Viết – đánh giá và biên tập, Viết – bản thảo gốc, Xác thực, Phần mềm, Phương pháp luận, Nghiên cứu, Khái niệm hóa. Mikael Asplund: Viết – đánh giá và biên tập, Tìm kiếm tài trợ, Khái niệm hóa.

Tuyên bố về lợi ích cạnh tranh

Các tác giả xin tuyên bố những lợi ích tài chính/mối quan hệ cá nhân sau đây có thể được coi là những lợi ích cạnh tranh tiềm ẩn: Charilaos Skandylas báo cáo rằng hỗ trợ tài chính và chi phí xuất bản bài báo được cung cấp bởi Ủy ban Châu Âu. Mikael Asplund báo cáo rằng hỗ trợ tài chính được cung cấp bởi Quỹ Nghiên cứu Chiến lược Thụy Điển. Nếu có các tác giả khác, họ xin tuyên bố rằng họ không có lợi ích tài chính hoặc mối quan hệ cá nhân cạnh tranh nào được biết đến có thể ảnh hưởng đến công trình được báo cáo trong bài báo này.

Lời cảm ơn

Tác giả đầu tiên được Chương trình Khung Horizon Europe hỗ trợ thông qua thỏa thuận tài trợ số 101120779. Tác giả thứ hai được Quỹ Nghiên cứu Chiến lược Thụy Điển hỗ trợ thông qua dự án số FUS21-0033.

Machine Translated by Google

Bảng 12
Tiện ích quyết định mục tiêu.

Nhân tố	Cân nặng	Giá trị
Số lượng dịch vụ (S)	0,2	$\frac{\text{phút}(S,10)}{10}$
Số lượng lỗ hổng (V)	0,2	$\frac{\text{phút}(V^2,10)}{10}$
Số lượng kết nối (C)	0,2	$\frac{\text{phút}(C^{1,5},10)}{10}$
Nhà nước khai thác (E)	0,4	0,73, = 0,9, = 1.0, = 0,23, = 2

Bảng 13
Tiện ích quyết định tấn công.

Nhân tố	Cân nặng	Giá trị
Vectơ tấn công (V)	0,3	1.0, = 0,73, = 0,64, = 0,23, = *h*
Độ phức tạp của cuộc tấn công (C)	0,2	1.0, = 0,57, = *h*
Quyền bắt buộc (P)	0,2	1.0, = 0,73, = 0,32 = *h*
Tương tác người dùng (U)	0,1	1.0, = 0,73, =
Thời gian chạy (T)	0,2	1.0, = 0,73, = 0,31, = 0,12, =

Bảng 14
Tiện ích quét quyết định.

Nhân tố	Cân nặng	Giá trị
Phạm vi quét (R)	0,25	1.0, = 0,73, = 0,32, =
Số lượng mục tiêu (T)	0,25	1.0, = 0,73, = 0,32, =
Thời lượng quét (D)	0,25	1.0, = 0,73, = 0,31, = 0,12, =
Độ phức tạp quét (C)	0,25	1.0, = 0,73, = *h*

Bảng 15
Ví dụ về các công cụ hệ thống được quản lý và phân loại của chúng.

Tên công cụ	Vai trò công cụ	Kỹ thuật ATT&CK
nmap	thăm dò	Quét chủ động: Quét các khối IP
cá đuối	thăm dò	Quét chủ động: Quét danh sách từ
Trình báo cáo	thăm dò	Khám phá dịch vụ mạng
tùy chỉnh khám phá NSE	thăm dò	Lọc tự động
bản đồ sql	hoạt động	Khai thác ứng dụng công khai
NSE brute	hoạt động	Brute Force: Bẻ khóa mật khẩu
hydra	hoạt động	Brute Force: Bẻ khóa mật khẩu
msfvenom	hoạt động	Phát triển năng lực: Khai thác
trình tạo	hoạt động	Khai thác để leo thang đặc quyền
shell	hoạt động	Nhiệm vụ/Công việc theo lịch trình: Cron
pickle shell của metasploit cron	hoạt động hoạt động	Khai thác để leo thang đặc quyền
mimikatz	Dumping thông tin đăng nhập hệ điều hành sau khi khai thác	
tcpdump	Đánh hơi mạng sau khai thác	
linuxprivchecker	Liệt kê nhật ký sau khai thác	
hashcat	hậu khai thác	Brute Force: Bẻ khóa mật khẩu
netcat	sau khai thác từ xa	
xoăn	Mạng lưới hậu khai thác Swiss Knife	
thống kê mạng	Khám phá dịch vụ mạng sau khai thác	
[illegible]	hậu khai thác	Khám phá quy trình

cho thấy cách chuyển đổi biểu diễn của thử nghiệm thâm nhập vấn đề đối với các hình thức của chúng ta. Các công trình liên quan khác sử dụng phương pháp học tăng cường, ví dụ, Chowdhary và cộng sự (2020), Hu và cộng sự (2020) và Zhou et al. (2021) có thể được chuyển đổi theo một quá trình tương tự như chúng tôi mô tả dưới đây.

Ví dụ 2. Trong Zhou et al. (2019), một thử nghiệm thâm nhập được đưa ra bởi một quá trình quyết định Markov (Puterman, 2014), = ,, , , Ở đâu:

- là một bộ , , , tương ứng với một máy chủ. là một mã định danh máy, tương ứng với hệ điều hành của máy hệ thống, là tập hợp các cổng mở của máy, là tập hợp các các dịch vụ đã biết đang chạy trên máy và là máy trạng thái bóc lột,
- là tập hợp các hành động kiểm tra thâm nhập có sẵn, là , xác suất một hành động sẽ dẫn từ trạng thái này đến trạng thái khác trạng thái khác là phần thưởng tương ứng.

Phép biến đổi sau đây ánh xạ thành:

1. Mọi được ánh xạ tới một thành phần , , và mỗi cái được ánh xạ tới các thuộc tính thành phần tương ứng của , , và . Đối với mỗi dịch vụ, chúng tôi tạo ra một giao diện và cổng mở tương ứng là một thuộc tính: .
2. Mọi hành động được ánh xạ tới một phép quét hoặc tới một bước tấn công. Mỗi bước tấn công cũng cấu thành một cuộc tấn công , vì các tác giả trong Zhou et al. (2019) không phân biệt giữa các bước tấn công và các đòn tấn công hoàn chỉnh.
3. Xác suất hành động và phần thưởng, có thể được mô hình hóa thông qua một chiến = , trong đó , + lưu trữ và trả lược được sử dụng để cập nhật các giá trị của họ và + về hành động có phần thưởng cao nhất trong trạng thái hiện tại .

Chi tiết triển khai và nghiên cứu điển hình

Xem Bảng 12–16.

Tính khả dụng của dữ liệu

Chúng tôi cung cấp mã nguồn công cụ tại: https://gitfront.io/r/người gửi ẩn danh/P2LRhxvh9L7z/ADAPT/. Xin lưu ý rằng ADAPT

Phụ lục

Bản đồ (Zhou et al., 2019) vào mô hình của chúng tôi

Vì Zhou et al. (2019) là công trình có liên quan gần nhất sử dụng học tăng cường để đạt được thử nghiệm thâm nhập hộp đen, chúng tôi

Machine Translated by Google

Bảng 16
Mô tả cờ.

[illegible]	Sự miêu tả
0	Thực hiện trinh sát và phát hiện để lập kế hoạch hoạt động
1	(i) Thực thi mã độc trên các thiết bị từ xa (ii) Thu thập và lọc dữ liệu từ môi trường máy tính
2	Thực hiện trinh sát và phát hiện để lập kế hoạch hoạt động truy cập thông tin xác thực, chẳng hạn như: tên tài khoản, mật khẩu và mã thông báo truy cập
3	(i) Thực hiện trinh sát và phát hiện để lập kế hoạch truy cập thông tin xác thực hoạt động, chẳng hạn như: tên tài khoản, mật khẩu và mã thông báo truy cập (ii) Đạt được quyền truy cập ban đầu vào mạng và hệ thống
4	Thực hiện trinh sát và phát hiện để: (i) kế hoạch hoạt động (ii) đạt được quyền truy cập ban đầu vào mạng và hệ thống (iii) thực thi mã độc trên các thiết bị từ xa (iv) thiết lập khả năng chỉ huy và kiểm soát để giao tiếp với các hệ thống bị xâm phạm (v) tồn tại trên mạng bằng cách duy trì quyền truy cập qua các lần gián đoạn (vi) di chuyển theo chiều ngang, xoay quanh môi trường tính toán
5	(i) Thực thi mã độc trên các thiết bị từ xa (ii) Đạt được quyền truy cập ban đầu vào mạng và hệ thống (iii) Thiết lập khả năng chỉ huy và kiểm soát để giao tiếp với các hệ thống bị xâm phạm.
6	(i) Thực hiện trinh sát và phát hiện để lập kế hoạch hoạt động (ii) Thông tin truy cập, chẳng hạn như tên tài khoản, mật khẩu và mã thông báo truy cập (iii) Đạt được quyền truy cập ban đầu vào mạng và hệ thống (iv) Thực thi mã độc trên các thiết bị từ xa (v) thiết lập khả năng chỉ huy và kiểm soát để giao tiếp với các hệ thống bị xâm phạm (vi) Di chuyển theo chiều ngang, xoay quanh môi trường tính toán (vii) Thu thập và lọc dữ liệu từ môi trường máy tính.
7	(i) Thu thập và lọc dữ liệu từ môi trường máy tính (ii) Thực thi mã độc trên các thiết bị từ xa
8	(i) Thực thi mã độc trên các thiết bị từ xa (ii) Thiết lập khả năng chỉ huy và kiểm soát để giao tiếp với các hệ thống bị xâm phạm (iii) nâng cao đặc quyền trên các hệ thống để có được quyền cấp cao hơn (iv) thu thập và lọc dữ liệu từ môi trường máy tính
9	(i) Thực hiện trinh sát và phát hiện để lập kế hoạch hoạt động (ii) thu thập và lọc dữ liệu từ môi trường máy tính
10	(i) Thiết lập các nguồn lực để hỗ trợ các hoạt động an ninh tấn công (ii) Đạt được quyền truy cập ban đầu vào mạng và hệ thống (iii) Thực thi mã độc trên các thiết bị từ xa (iv) Thiết lập khả năng chỉ huy và kiểm soát để giao tiếp với các hệ thống bị xâm phạm (v) Duy trì kết nối mạng bằng cách duy trì quyền truy cập trong suốt thời gian gián đoạn (vi) Di chuyển theo chiều ngang, xoay quanh môi trường tính toán

Bảng 17
Chi tiết biểu đồ khai thác Metasploitable2.

Nút	Sự miêu tả	Thời gian chạy (giây)	Nút	Sự miêu tả
S0	Quét mạng	30	T610	ssh
S1	LinPEAS	7	T611	telnet
S2	LinEnum.sh	9	T612	smtp
S3	linuxprivchecker.py Rò	12	I3	hậu tiến
E0	rỉ thông tin đăng	10	I4	httpd
E1	nhập SSH Bruteforce	2	I5	vsftpd
E2	Liệt kê người dùng	7	I6	vnc
E3	Mật khẩu Bruteforce	5.8	I7	đăng nhập
E4	Tiêm đối số CGI	8.8	I8	rsh
E5	Cửa sau	8	I9	rexec
E6	Bruteforce thông tin xác thực	5,69	I10	NFS
E7	Truy cập không xác thực	1	I11	UnrealIRCD
E8	Truy cập không xác thực	1	I12	điệu samba
E9	Truy cập không xác thực	1	I13	Jawarmi
E10	Gắn kết thư mục	2	I14	mysql
E11	Cửa sau	17	C1	CVE-2008-0900 có thể khai thác
E12	Thực thi lệnh	3	C2	CVE-2008-0600 có thể khai thác
E13	Tải lớp từ xa	16	C3	CVE-2009-1046 có thể khai thác
E14	Vỏ từ xa	5	C4	thông tin đăng nhập msfadmin
E15	Vỏ từ xa	1	C5	vỏ dữ liệu www
E16	CVE-2008-0900	1	C6	thông tin đăng nhập gốc
E17	CVE-2008-0600	1		
E18	CVE-2009-1046	1		
P0	sudo không cần mật khẩu	0,1		

Machine Translated by Google

Bảng 18
Chi tiết về nút khai thác Metasploitable3.

Nút	Sự miêu tả	Thời gian chạy	Nút	Sự miêu tả
S0	Quét mạng	120	T010	ssh
S1	Quét EternalBlue	1	T011	winrm
E0	Bruteforce thông tin xác thực	9	T012	mèo đực
E1	Bruteforce thông tin xác thực	8	I3	cá thủy tinh
E2	Bruteforce thông tin xác thực	7	I4	jenkins
E3	Bruteforce thông tin xác thực	8	I5	caidao
E4	Thực thi lệnh hệ điều hành	1	I6	tìm kiếm đàn hồi
E5	Bruteforce thông tin xác thực	7	I7	trục
E6	Thực thi mã từ xa	1	I9	webdav
E7	Tải lên Shell từ xa	2	I10	jmx
E8	Tải lên Shell từ xa	2	I11	wordpress
E9	Tải lớp học từ xa	2	I12	PHPMyAdmin
E10	Thực thi mã từ xa	1,5	I13	rubyonrails
E11	Bruteforce thông tin xác thực	8	I14	thanh chống
E12	Bruteforce thông tin xác thực	9	I14	quản lý động cơ
E13	Bruteforce thông tin xác thực	12	I15	iis-ftp
E14	Bruteforce thông tin xác thực	14	I16	mysql
E15	Bruteforce thông tin xác thực	11	I17	iis-http
E16	Bruteforce thông tin xác thực	8	C0	giấy tờ tùy thân của người lang thang
E17	Bruteforce thông tin xác thực	15	C1	giấy tờ tùy thân của người lang thang
E19	Tải lên TCP Shell War	2	C2	giấy tờ tùy thân của người lang thang
E20	Tải lên TCP Shell War	2	C3	thông tin xác thực splot
E21	Truy cập cửa sau	1	C4	giấy tờ tùy thân của người lang thang
E22	Thực thi mã từ xa	1	C5	thông tin đăng nhập gốc
E23	Tải lên Shell từ xa	2	C6	thông tin khai thác
E24	Tải lên quyền truy cập	2	C7	thông tin đăng nhập của quản trị viên
E26	shell Remote Shell	1	C8	duyệt thư mục
E27	truy cập shell	1	C9	thông tin xác thực gốc
E28	Shell TCP đảo ngược	1	C10	thông tin đăng nhập gốc
E29	Shell gốc TCP đảo ngược	1	C11	thông tin đăng nhập gốc
E30	Màu xanh vĩnh cửu	1	C12	Tín dụng Hệ thống thẩm quyền NT
E31	CVE2015-1635	1	C13	Quá trình đổ bộ nhớ
P0	Tải trọng chiến tranh độc hại	1		

dựa trên plugin và do những cân nhắc về mặt đạo đức, các plugin xâm nhập hoặc gây gián đoạn hoạt động sẽ chỉ được cung cấp cho các nhà nghiên cứu theo yêu cầu. Về tính khả dụng của dữ liệu trong các nghiên cứu điển hình của chúng tôi, Metasploitable2 và Metasploitable3 đều mở và có sẵn miễn phí trực tuyến. Khi nói đến mạng VM, chúng tôi không thể phân phối nó một cách công khai vì nó đang được sử dụng làm tài liệu kiểm tra trong các khóa học đang hoạt động nhưng chúng ta có thể cung cấp quyền truy cập theo yêu cầu.

Tài liệu tham khảo

Alhamed, M., Rahman, MMH, 2023. Tổng quan tài liệu có hệ thống về sự thâm nhập thử nghiệm trong mạng: Hướng nghiên cứu trong tương lai. Appl. Sci. 13 (12), http://dx.doi.org/10.3390/app13126986, Đường dẫn https://www.mdpi.com/2076-3417/13/12/6986.

Anand, P., 1995. Nền tảng của Lựa chọn Hợp lý trong Rủi ro. Trong: Nền tảng của Lựa chọn hợp lý đang gặp rủi ro, Clarendon Press, URL https://books.google.se/books?id=UCzHwAEACAAJ.

Bratus, S., Shubina, A., 2017. Khai thác như tái sử dụng mã: Về nhu cầu chính thức hóa. Công nghệ thông tin - 59 (2), 93–100. http://dx.doi.org/10.1515/itit-2016-0038.

Calinescu, R., Mirandola, R., Perez-Palacin, D., Weyns, D., 2020. Hiểu biết sự không chắc chắn trong các hệ thống tự thích ứng. Trong: Hội nghị quốc tế IEEE năm 2020 về Máy tính tự động và hệ thống tự tổ chức. ACSOS, trang 242–251. http://dx.doi.org/10.1109/ACSOS49614.2020.00047.

Chen, J., Hu, S., Zheng, H., Xing, C., Zhang, G., 2023. GAIL-PT: Một trí thông minh khuôn khổ thử nghiệm thâm nhập với phương pháp học mô phỏng đối kháng tạo sinh. Máy tính. Bảo mật. 126, 103055. http://dx.doi.org/10.1016/j.cose.2022.103055, URL https://www.sciencedirect.com/science/article/pii/S0167404822004473.

Chen, Y., Wah, BW, Hsu, C.-W., 2006. Lập kế hoạch thời gian sử dụng phân vùng mục tiêu phụ và giải quyết trong SGPlan. J. Artificial Intelligence Res. 26, 323–369, URL https://api.semanticscholar.org/CorpusID:12806220.

Cheng, BHC, de Lemos, R., Giese, H., Inverardi, P., Magee, J., Andersson, J., Becker, B., Bencomo, N., Brun, Y., Cukic, B., Serugendo, GD, Dustdar, S., Finkelstein, A., Gacek, J., Geichs, K., Grassi, V., Karsai, G., Kienle, H. M., Kramer, J., Litoiu, M., Malek, S., Mirandola, R., Müller, HA, Park, S., Shaw, M., Tichy, M., Tivoli, M., Weyns, D., Whittle, J., 2009. Kỹ thuật phần mềm cho khả năng tự thích ứng Hệ thống: Lộ trình nghiên cứu. Trong: Kỹ thuật phần mềm cho hệ thống tự thích ứng [Kết quả của Hội thảo Dagstuhl]. Trong: Ghi chú bài giảng về Khoa học máy tính, Tập. 5525, Springer, trang 1–26. http://dx.doi.org/10.1007/978-3-642-02161-9_1.

Chowdhary, A., Huang, D., Mahendran, JS, Romo, D., Đặng, Y., Sabur, A., 2020. Phân tích bảo mật tự động và kiểm tra thâm nhập. Trong: 2020 Quốc tế lần thứ 16 Hội nghị về Di động, Cảm biến và Mạng. MSN, trang 508–515. http://dx.doi.org/10.1109/MSN50589.2020.00086.

Clintswood, Lie, D.G., Kuswandana, L., Nadia, Achmad, S., Suhartono, D., 2023. Ứng dụng học máy trong tự động hóa kiểm thử xâm nhập. Trong: Hội nghị Quốc tế lần thứ 3 về Kỹ thuật Điện, Điện tử và Hệ thống Thông minh năm 2023 (ICE3IS). trang 322–326. http://dx.doi.org/10.1109/ICE3IS59323.2023.10335188.

Cook, M., Prisaca, D., Quinn, S., Waltermire, D., 2018. Tự động hóa nội dung bảo mật Yêu cầu kiểm tra chương trình xác thực giao thức (SCAP) phiên bản 1.3. http://dx.doi.org/10.6028/NIST.IR.7511r5.

Đặng, G., Liu, Y., Mayoral-Vilches, V., Liu, P., Li, Y., Xu, Y., Zhang, T., Liu, Y., Pinzger, M., Rass, S., 2024. PentestGPT: Đánh giá và khai thác ngôn ngữ lớn các mô hình kiểm tra thâm nhập tự động. Trong: Hội nghị chuyên đề bảo mật USENIX lần thứ 33 (USENIX Security 24). Hiệp hội USENIX, Philadelphia, PA, trang 847–864, URL https://www.usenix.org/conference/usenixsecurity24/presentation/deng.

Dullien, T., 2020. Máy móc kỳ lạ, khả năng khai thác và khả năng không khai thác được. IEEE Trans. Emerg. Top. Comput. 8 (2), 391–403. http://dx.doi.org/10.1109/TETC.2017.2785299.

Durkota, K., Lisy, V., 2014. Tính toán các chính sách tối ưu cho đồ thị tấn công có hành động thất bại và chi phí.

Faillon, M.-A., Bout, B., Francq, J., Neal, C., Boulahia-Cuppens, N., Cuppens, F., Yaich, R., 2024. Cách để phù hợp hơn với việc học tăng cường cho kiểm tra thâm nhập: Một cách tiếp cận theo thứ bậc. Trong: Garcia-Alfaro, J, Kozik, R, Choraś, M, Katsikas, S. (Biên tập viên), Bảo mật máy tính – ESORICS 2024. Springer Nature Thụy Sĩ, Cham, trang 313–332.

Fox, M., Long, D., 2003. PDDL2.1: Một phần mở rộng của PDDL để thể hiện các miền lập kế hoạch thời gian. ArXiv abs/1106.4561 Đường dẫn https://api.semanticscholar.org/CorpusID:1397894.

Ghanem, MC, Chen, TM, 2020. Học tăng cường để kiểm tra xâm nhập mạng hiệu quả. Thông tin 11 (1), http://dx.doi.org/10.3390/info11010006, URL https://www.mdpi.com/2078-2489/11/1/6.

Ghanem, MC, Chen, TM, Nepomuceno, EG, 2023. Học tăng cường phân cấp để kiểm tra xâm nhập tự động hiệu quả và hiệu suất cao trên các mạng lớn. J. Trí tuệ. Thông tin Hệ thống. 60 (2), 281–303. http://dx.doi.org/10.1007/S10844-022-00738-0.

van Glabbeek, R., 2001. CHƯƠNG 1 - phổ thời gian tuyến tính - thời gian phân nhánh i.**điều này là phần mở rộng của [20]. Nghiên cứu được báo cáo trong bài báo này đã được bắt đầu tại CWI tại Amsterdam, tiếp tục học tại trường đại học kỹ thuật Munich và hoàn thành tại trường đại học Stanford. Nó đã được hỗ trợ bởi sonderforschungsbereich 342 của TU münchen và ONR theo số tài trợ N00014-92-j-1974. Một phần của nó được thực hiện trong quá trình chuẩn bị cho một khóa học về ngữ nghĩa đồng thời so sánh, được trình bày tại trường đại học amsterdam, mùa xuân năm 1988. Trong: Bergstra, J., Ponse, A.,

Machine Translated by Google

Smolka, S. (Biên tập), Sổ tay Đại số Quá trình. Elsevier Science, Amsterdam, trang 3–99. http://dx.doi.org/10.1016/B978-044482830-9/50019-9, Đường dẫn https://www.sciencedirect.com/science/article/pii/B9780444828309500199 . Phiên bản màu của bài báo này có sẵn tại http://boole.stanford.edu/pub/spectruml.ps.gz Ngữ nghĩa của các quá trình tuần tự cụ thể.

Glazier, TJ, Schmerl, BR, Cámara, J., Garlan, D., 2017. Lý thuyết tiện ích cho các hệ thống tự thích ứng. URL https://api.semanticscholar.org/CorpusID:13701643.

Hilario, E., Azam, S., Sundaram, J., Imran Mohammed, K., Shanmugam, B., 2024. Trí tuệ nhân tạo tạo ra cho kiểm thử thâm nhập: tốt, xấu, tệ. Int. J. Inf. Secur. 23 (3), 2075–2097. http://dx.doi.org/10.1007/s10207-024-00835-x.

Hoang, L.V., Nhu, N.X., Nghia, T.T., Quyen, N.H., Pham, V.-H., Duy, P.T., 2022. Tận dụng học tăng cường sâu để tự động hóa thử nghiệm xâm nhập trong giai đoạn trinh sát và khai thác. Trong: Hội nghị Quốc tế RIVF 2022 về Công nghệ Máy tính và Truyền thông. RIVF, trang 41–46. http://dx.doi.org/ 10.1109/RIVF55975.2022.10013801.

Hoffmann, J., 2002. Mở rộng FF sang các biến trạng thái số. Trong: Kỷ yếu Hội nghị Trí tuệ Nhân tạo Châu Âu lần thứ 15. ECAI '02, IOS Press, NLD, trang 571–575.

Holik, F., Horalek, J., Marik, O., Neradova, S., Zitta, S., 2014. Kiểm tra thâm nhập hiệu quả với nền tảng và phương pháp Metasploit. Trong: Hội nghị chuyên đề quốc tế lần thứ 15 về Trí tuệ tính toán và Tin học của IEEE năm 2014. CINTI, trang 237–242. http://dx.doi.org/10.1109/CINTI.2014.7028682.

Hu, Z., Beuran, R., Tan, Y., 2020. Kiểm tra thâm nhập tự động bằng học tăng cường sâu. Trong: Hội thảo chuyên đề Châu Âu về An ninh và Quyền riêng tư của IEEE năm 2020 (EuroS&PW). trang 2–10. http://dx.doi.org/10.1109/EuroSPW51379.2020.00010.

Jackson, M., 1997. Ý nghĩa của các yêu cầu. Ann. Softw. Eng. 3 (1), 5–21.

Jagamogan, RS, Ismail, SA, Hassan, NH, Abas, H., 2022. Quy trình kiểm tra xâm nhập sử dụng máy học. Trong: Hội nghị Quốc tế lần thứ 4 năm 2022 về Cảm biến Thông minh và Ứng dụng. ICSSA, trang 58–63. http://dx.doi.org/10.1109/ICSSA54161.2022.9870951.

Jansen, S., 2011. Phương pháp tiện ích đa thuộc tính. ISBN: 978-90-481-8893-2, trang. 101–125.

Keeney, RL, Raiffa, H., 1993. Quyết định với nhiều mục tiêu: Sở thích và Đánh đổi giá trị. Nhà xuất bản Đại học Cambridge.

Kephart, JO, Chess, DM, 2003. Tầm nhìn về điện toán tự động. Máy tính 36 (1), 41–50. http://dx.doi.org/10.1109/MC.2003.1160055.

Kwiatkowska, MZ, 2016. Kiểm tra mô hình và tổng hợp chiến lược cho trò chơi ngẫu nhiên: Từ lý thuyết đến thực tiễn. Trong: Chatzigiannakis, I., Mitzenmacher, M., Rabani, Y., Sangiorgi, D. (Eds.), Hội thảo quốc tế lần thứ 43 về Automata, Ngôn ngữ và Lập trình (ICALP 2016). Trong: Thủ tục tố tụng quốc tế về tin học của Leibniz (LIPIcs), Tập. 55, Schloss Dagstuhl – Leibniz-Zentrum für Informatik, Dagstuhl, Đức, trang 4:1–4:18. http://dx.doi.org/10.4230/LIPIcs.ICALP.2016.4, URL https: //drops.dagstuhl.de/entities/document/10.4230/LIPIcs.ICALP.2016.4.

Lee, N., 2015. Thách thức lớn về an ninh mạng của DARPA (2014–2016). Trong: Chống khủng bố và An ninh mạng: Nhận thức toàn diện về thông tin. Springer International Publishing, Cham, trang 429–456.

Li, Q., Zhang, M., Shen, Y., Wang, R., Hu, M., Li, Y., Hao, H., 2023. Một mô hình học tăng cường sâu phân cấp với kiến thức chuyên môn trước đó để kiểm tra thâm nhập thông minh. Comput. Secur. 132, 103358. http://dx.doi.org/10. 1016/j.cose.2023.103358, Đường dẫn https://www.sciencedirect.com/science/article/pii/ S0167404823002687.

Li, M., Zhu, T., Yan, H., Chen, T., Lv, M., 2025. HER-PT: Một khuôn khổ kiểm tra xâm nhập thông minh với khả năng xem lại kinh nghiệm. Comput. Secur. 152, 104357. http://dx.doi.org/10.1016/j.cose.2025.104357, Đường dẫn https://www.sciencedirect.com/science/article/pii/S016740482500046X .

Obes, JL, Sarraute, C., Richarte, G., 2013. Lập kế hoạch tấn công trong thế giới thực. CoRR abs/1306.4044 Đường dẫn http://arxiv.org/abs/1306.4044.

Ou, X., Boyer, WF, McQueen, MA, 2006. Một phương pháp tiếp cận có khả năng mở rộng để tạo đồ thị tấn công. Trong: Kỷ yếu Hội nghị ACM lần thứ 13 về An ninh Máy tính và Truyền thông. CCS '06, ACM, New York, NY, Hoa Kỳ, trang 336–345. http://dx.doi.org/10.1145/1180405.1180446 , Địa chỉ http://doi.acm.org/10.1145/1180405. 1180446.

Puterman, ML, 2014. Quy trình quyết định Markov: Lập trình động ngẫu nhiên rời rạc . John Wiley & Sons.

Sarraute, C., Buffet, O., Hoffmann, J., 2013. Kiểm tra thâm nhập==Giải quyết POMDP?. ArXiv abs/1306.4714 URL https://api.semanticscholar.org/CorpusID:14462292.

Sarraute, C., Richarte, G., Lucángeli Obes, J., 2011. Một thuật toán tìm đường tấn công tối ưu trong các tình huống không xác định. Trong: Kỷ yếu Hội thảo ACM lần thứ 4 về An ninh và Trí tuệ Nhân tạo. CCS '11, ACM, http://dx.doi.org/10.1145/ 2046684.2046695.

Simon, R., Mees, W., 2024. SoK: So sánh các tác nhân kiểm tra xâm nhập tự động. Trong: Kỷ yếu Hội nghị Quốc tế lần thứ 19 về Tính khả dụng, Độ tin cậy và Bảo mật. ARES '24, Hiệp hội Máy tính, New York, NY, Hoa Kỳ, http://dx.doi.org/10.1145/3664476.3664484.

Standen, M., Lucas, M., Bowman, D., Richer, TJ, Kim, J., Marriott, DA, 2021. CybORG: Một phòng tập thể dục để phát triển các tác nhân mạng tự động. ArXiv abs/ 2108.09118 URL https://api.semanticscholar.org/CorpusID:237259783.

Tran, K., Akella, A., Standen, M., Kim, J., Bowman, D., Richer, TJ, One, C.-TLI, Two, I., 2021. Các tác nhân gia cố phân cấp sâu cho thử nghiệm thâm nhập tự động. ArXiv abs/2109.06449 URL https://api.semanticscholar.org/CorpusID: 237502821.

Vats, P., Mandot, M., Gosain, A., 2020. Tổng quan tài liệu toàn diện về kiểm tra xâm nhập và các ứng dụng của nó. Trong: Hội nghị Quốc tế lần thứ 8 năm 2020 về Độ tin cậy, Công nghệ Thông tin và Tối ưu hóa (Xu hướng và Định hướng Tương lai). ICRITO, trang 674–680. http://dx.doi.org/10.1109/ICRITO48877.2020.9197961. von Neumann, J., Morgenstern, O., 1947. Lý thuyết trò chơi và hành vi kinh tế, ấn bản thứ hai. Nhà xuất bản Đại học Princeton, New Jersey.

Wang, Y., Li, Y., Xiong, X., Zhang, J., Yao, Q., Shen, C., 2023. DQfD-AIPT: Một khuôn khổ kiểm tra xâm nhập thông minh kết hợp dữ liệu trình diễn của chuyên gia. Bảo mật. Cộng đồng. Mạng. 2023 (1), 5834434. http://dx.doi.org/10.1155/2023/5834434, Đường dẫn https://onlinelibrary.wiley.com/doi/abs/10.1155/2023/5834434.

Wang, Y., Liu, S., Wang, W., Zhou, C., Zhang, C., Jin, J., Zhu, C., 2025. Một khuôn khổ mô hình hóa thống nhất cho thử nghiệm xâm nhập tự động. URL https://api.semanticscholar.org/CorpusID:276408010 .

Weyns, D., 2018. Kỹ thuật hệ thống phần mềm tự thích ứng - Một chuyến tham quan có tổ chức. Trong: Hội thảo Quốc tế lần thứ 3 của IEEE về Nền tảng và Ứng dụng của Hệ thống Tự* (FAS*W) năm 2018. trang 1–2. http://dx.doi.org/10.1109/FAS-W.2018.00012.

Weyns, D., 2019. Kỹ thuật phần mềm cho các hệ thống tự thích ứng. Trong: Cẩm nang Kỹ thuật Phần mềm. Nhà xuất bản Quốc tế Springer, Cham, trang 399–443.

Williams, A., 2015. Hệ thống tự động: Các vấn đề dành cho các nhà hoạch định chính sách quốc phòng. CHUYỂN ĐỔI BỘ CHỈ HUY ĐỒNG MINH TỐI CAO CỦA NATO NORFOLK VA NORFOLK.

Zhou, S., Liu, J., Hou, D., Zhong, X., Zhang, Y., 2021. Kiểm tra thâm nhập tự động dựa trên mạng Q sâu được cải tiến. Appl. Sci. 11 (19), http://dx.doi.org/10.3390/ app11198823, Đường dẫn https://www.mdpi.com/2076-3417/11/19/8823.

Zhou, T.-y., Zang, Y.-c., Zhu, J.-h., Wang, Q.-x., 2019. NIG-AP: một phương pháp mới để kiểm tra thâm nhập tự động. Front. Inf. Technol. Electron. Eng. 20 (9), 1277–1288, URL https://doi.org/10.1631/FITEE.1800532.